

MÁQUINA DEBIAN HACKEADA

Marzo, 2025
Reportado por: Yulybeth Rios

Indice

Portada	01
Indice	02
Introducción	03
Objetivos	04
Metodología y Vulnerabilidades	05-25
Mitigación	26-37
Propuesta de prevención	38

Introducción

El siguiente informe detalla el pentesting realizado a una máquina, en la cuál un servidor fué comprometido. Se debía detener el hackeo con ataques controlados y si las hubiera explotar sus vulnerabilidades.

Objetivos

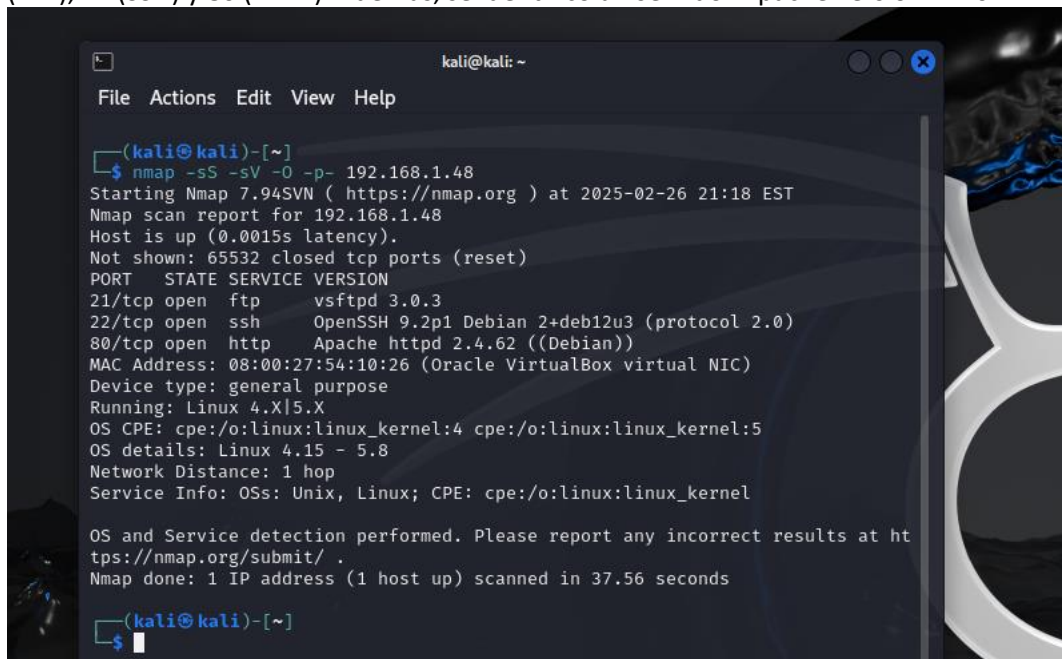
Como objetivo principal, se debía identificar qué estaba ocurriendo y detenerlo. Se investigó el sistema, los servicios y los servidores para, fundamentalmente, evitar la escalada de privilegios y mitigar cualquier otra vulnerabilidad. De esta manera, se podría volver a tener el servidor activo y se podría cumplir con los principios de disponibilidad, confidencialidad e integridad.

Metodología y vulnerabilidades

La primera acción que se realizó fue usar una máquina Kali para realizar un ping a la máquina comprometida. Luego de obtener respuesta, se realizó un escaneo de red y servicios, ya que se requería verificar qué puertos y servicios estaban abiertos para obtener información y pistas sobre qué servidor estaba siendo atacado.

NOTA: Por cada acción que se realizó, se describió lo encontrado y se adjuntó una imagen como evidencia de dicha acción. Cabe destacar que se permitió revisar y realizar explotaciones de vulnerabilidades en cualquier área de la máquina.

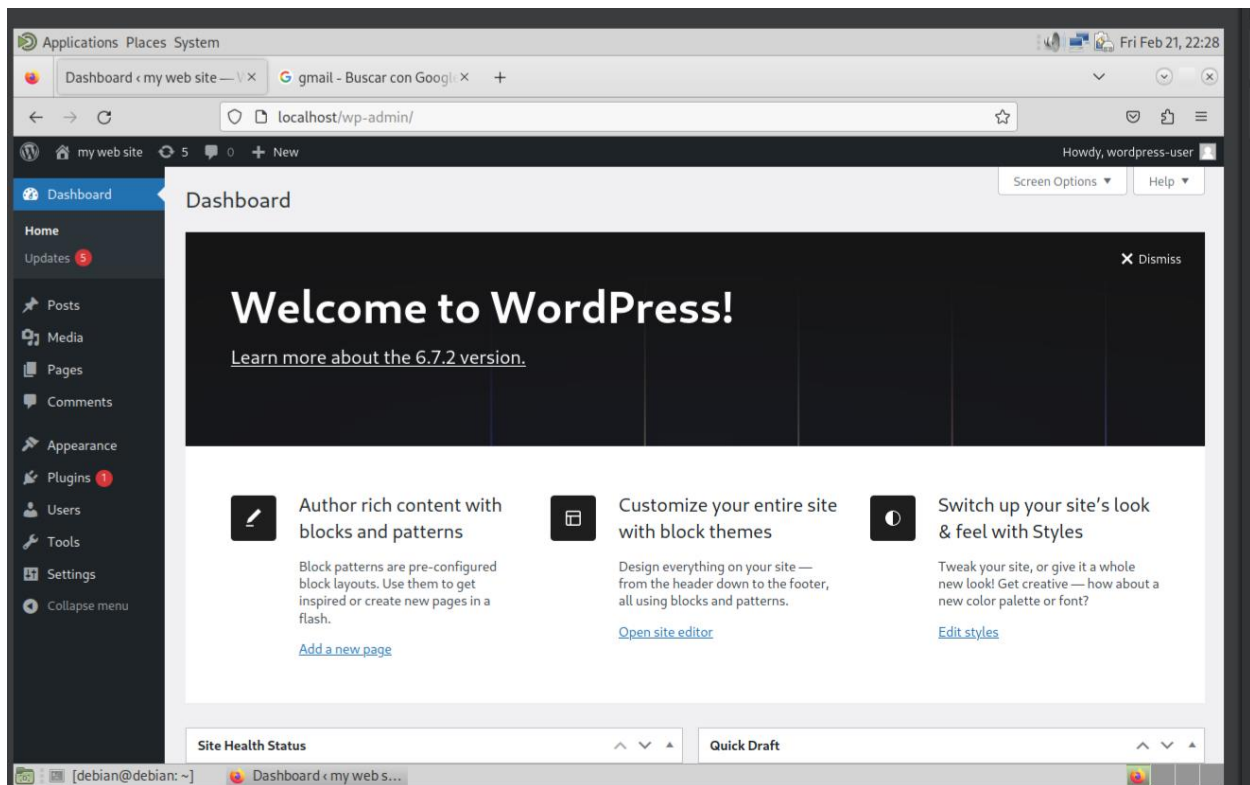
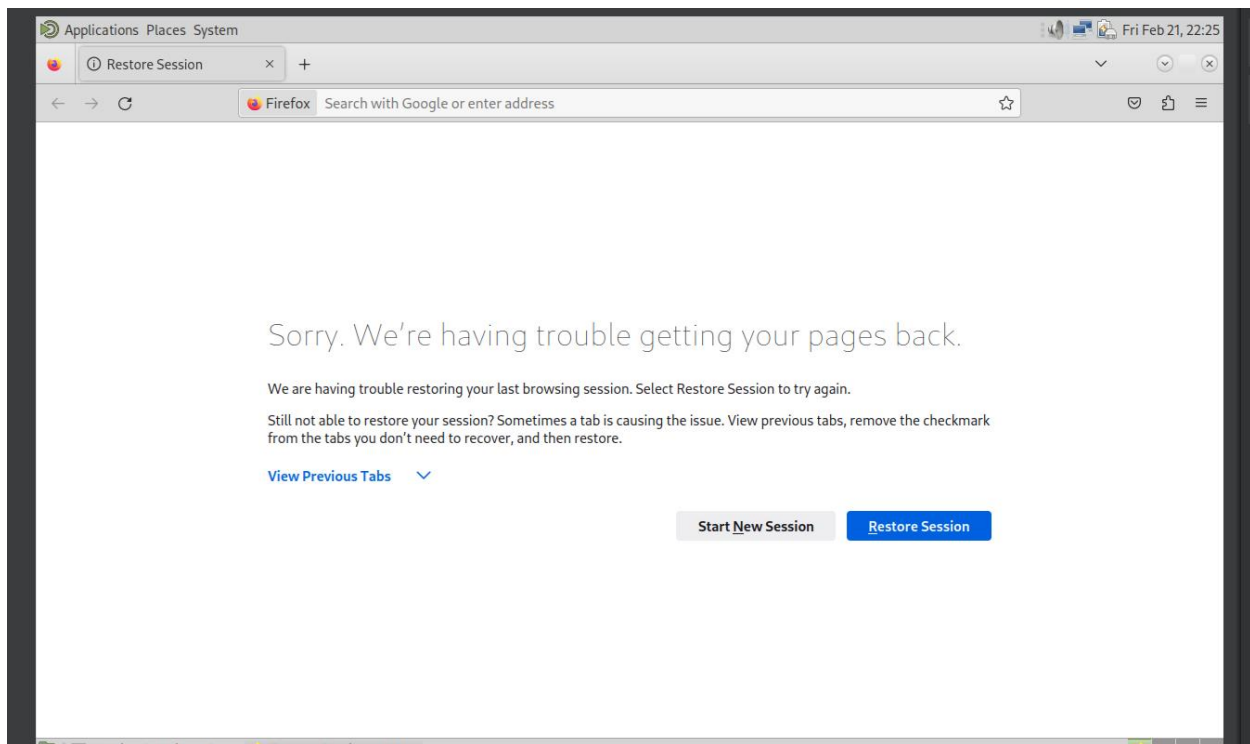
Se usó la herramienta Nmap, con la cual se detectó que la máquina tenía puertos abiertos como el 21 (FTP), 22 (SSH) y 80 (HTTP). Además, se identificó un servidor Apache versión 2.4.62.



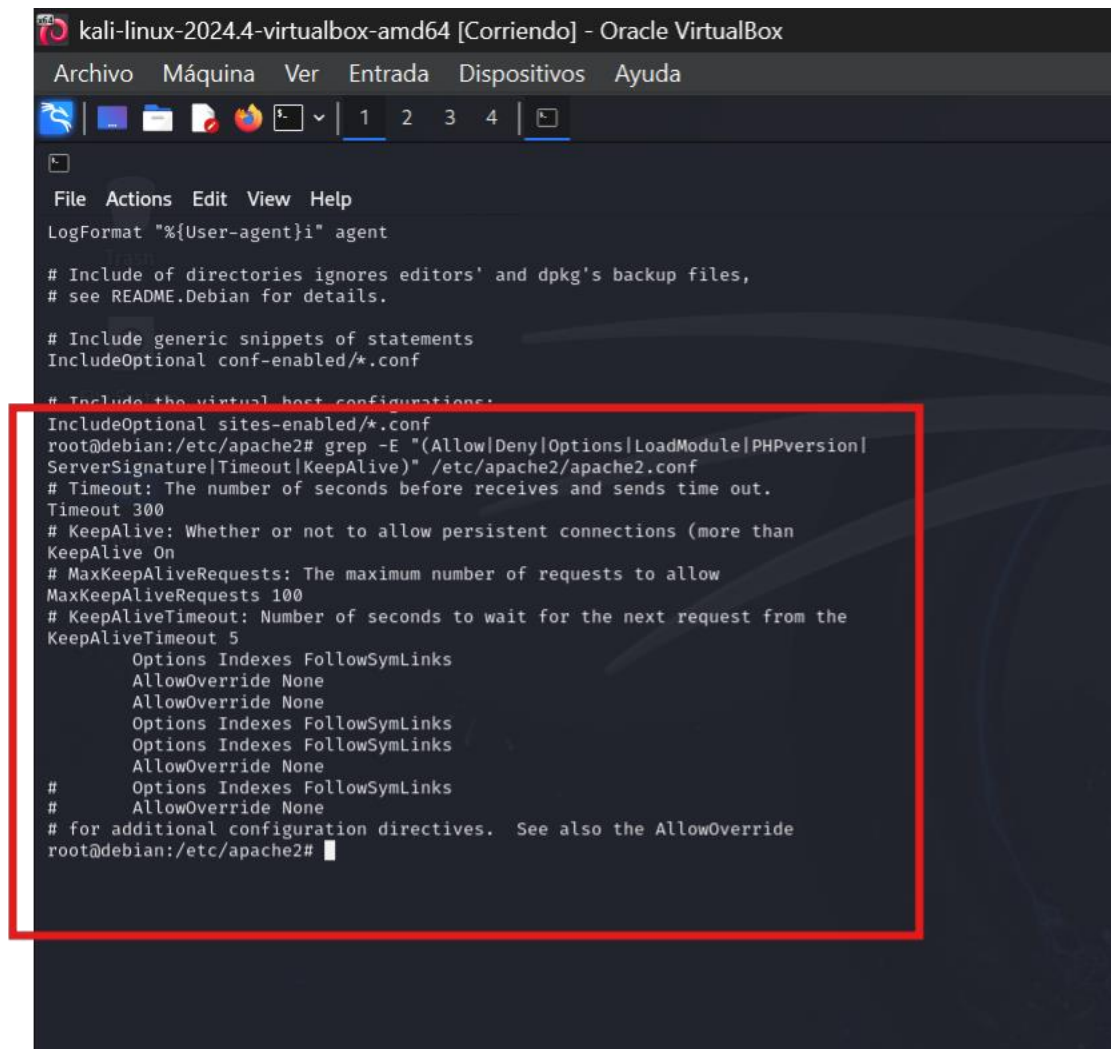
```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)-[~]  
$ nmap -sS -sV -O -p- 192.168.1.48  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-26 21:18 EST  
Nmap scan report for 192.168.1.48  
Host is up (0.0015s latency).  
Not shown: 65532 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 3.0.3  
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)  
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))  
MAC Address: 08:00:27:54:10:26 (Oracle VirtualBox virtual NIC)  
Device type: general purpose  
Running: Linux 4.X|5.X  
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5  
OS details: Linux 4.15 - 5.8  
Network Distance: 1 hop  
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 37.56 seconds  
  
(kali@kali)-[~]  
$
```

Se procedió a la revisión del servidor Apache, ya que este es un servidor web y está expuesto.

Dato: Desde la máquina comprometida, se ingresó a Firefox e inmediatamente se abrió una página para restaurar sesión, a la cual se procedió a permitir la restauración de sesión. La página que se abrió fue WordPress (donde se gestionan páginas web). No debería abrirse sin usuario y contraseña. Se procedió a obtener acceso remoto desde una máquina Kali hacia la máquina comprometida.



Obteniendo el acceso remoto y habiendo ocurrido el incidente en Firefox, lo cual afianzó la necesidad de revisar Apache2, se buscaron las configuraciones y se ejecutó un comando con la herramienta grep: `grep -E "(Allow|Deny|Options|LoadModule|PHPVersion|ServerSignature|Timeout|KeepAlive)" /etc/apache2/apache2.conf`. Se determinó que el directorio web estaba permitido, es decir, que se podía acceder a archivos sensibles.



The screenshot shows a terminal window titled "kali-linux-2024.4-virtualbox-amd64 [Corriendo] - Oracle VirtualBox". The terminal displays the contents of the Apache2 configuration file `/etc/apache2/apache2.conf`. A red rectangular box highlights the output of the command `grep -E "(Allow|Deny|Options|LoadModule|PHPVersion|ServerSignature|Timeout|KeepAlive)" /etc/apache2/apache2.conf`. The output shows several configuration directives, including `Options Indexes FollowSymLinks` and `AllowOverride None`, which are repeated multiple times. The terminal also shows the command prompt `root@debian:/etc/apache2#` and the command being executed.

```
kali-linux-2024.4-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
1 2 3 4
File Actions Edit View Help
LogFormat "%{User-agent}i" agent
# Include of directories ignores editors' and dpkg's backup files,
# see README.Debian for details.
# Include generic snippets of statements
IncludeOptional conf-enabled/*.conf
# Include the virtual host configurations:
IncludeOptional sites-enabled/*.conf
root@debian:/etc/apache2# grep -E "(Allow|Deny|Options|LoadModule|PHPVersion|
ServerSignature|Timeout|KeepAlive)" /etc/apache2/apache2.conf
# Timeout: The number of seconds before receives and sends time out.
Timeout 300
# KeepAlive: Whether or not to allow persistent connections (more than
KeepAlive On
# MaxKeepAliveRequests: The maximum number of requests to allow
MaxKeepAliveRequests 100
# KeepAliveTimeout: Number of seconds to wait for the next request from the
KeepAliveTimeout 5
    Options Indexes FollowSymLinks
    AllowOverride None
    AllowOverride None
    Options Indexes FollowSymLinks
    Options Indexes FollowSymLinks
    AllowOverride None
#     Options Indexes FollowSymLinks
#     AllowOverride None
# for additional configuration directives. See also the AllowOverride
root@debian:/etc/apache2#
```

El siguiente paso fue revisar los logs de Apache, como `access.log` y `error.log`, ya que estos registran accesos y errores. No se evidenció nada fuera de lo usual. Igualmente, allí también se usó la herramienta `grep`, la cual tampoco evidenció respuestas inusuales.

```
root@debian:/var/log/apache2# less access.log
root@debian:/var/log/apache2# less access.log
root@debian:/var/log/apache2# less error.log
root@debian:/var/log/apache2# grep -i "permission denied" error.log
root@debian:/var/log/apache2# grep -i "access denied" error.log
root@debian:/var/log/apache2# grep -i "file not found" error.log
root@debian:/var/log/apache2# grep -i "directory not found" error.log
root@debian:/var/log/apache2# grep -i "database error" error.log
root@debian:/var/log/apache2# grep -i "connectio refused" error.log
root@debian:/var/log/apache2# grep -i "connection refused" error.log
root@debian:/var/log/apache2# grep -i "access denied" error.log
root@debian:/var/log/apache2# grep -i "configuration error" error.log
root@debian:/var/log/apache2#
```

También se revisaron los logs del sistema, pero no se encontraron en el directorio habitual. Por lo cual, se usó journalctl, y lo único diferente fue un ingreso satisfactorio desde una IP desconocida.


```
debian@debian: /var/log
File Actions Edit View Help
Oct 08 16:14:16 debian sshd[560]: Received signal 15; terminating.
Oct 08 16:14:16 debian systemd[1]: ssh.service: Deactivated successfully.
Oct 08 16:14:16 debian systemd[1]: Stopped ssh.service - OpenBSD Secure Shell server.
Oct 08 16:14:16 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server.
Oct 08 16:14:16 debian sshd[5341]: Server listening on 0.0.0.0 port 22.
Oct 08 16:14:16 debian sshd[5341]: Server listening on :: port 22.
Oct 08 16:14:16 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
-- Boot 342683d8f35244b08c4f3863f2978eca --
Oct 08 16:43:18 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server.
Oct 08 16:43:18 debian sshd[543]: Server listening on 0.0.0.0 port 22.
Oct 08 16:43:18 debian sshd[543]: Server listening on :: port 22.
Oct 08 16:43:18 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
-- Boot d28e179bf5884b25bf94452c79fd0afa --
Oct 08 16:48:02 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server.
Oct 08 16:48:02 debian sshd[555]: Server listening on 0.0.0.0 port 22.
Oct 08 16:48:02 debian sshd[555]: Server listening on :: port 22.
Oct 08 16:48:02 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
-- Boot af0a79f76920440c8e08594d6547449b --
Oct 08 17:28:37 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server.
Oct 08 17:28:38 debian sshd[550]: Server listening on 0.0.0.0 port 22.
Oct 08 17:28:38 debian sshd[550]: Server listening on :: port 22.
Oct 08 17:28:38 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
Oct 08 17:40:59 debian sshd[1650]: Accepted password for root from 192.168.0.134 port 22.
Oct 08 17:40:59 debian sshd[1650]: pam_unix(sshd:session): session opened for user root.
Oct 08 17:40:59 debian sshd[1650]: pam_env(sshd:session): deprecated reading of user env.
-- Boot 7cc07c37204c4c649e1880a444c9bb9a --
lines 15-40
```

Se dirigió al directorio raíz de WordPress, y allí se revisaron los permisos de los archivos. Se encontró que todos estaban mal configurados. Por ejemplo, un archivo muy importante, wp-config.php (donde se encuentran los detalles de la configuración con la base de datos), tenía permisos excesivos para cualquier grupo o usuario.

```
</body>
</html>
debian@debian:/var/www/html$ ls -l
total 248
-rwxrwxrwx 1 www-data www-data 10701 Sep 30 10:44 index.html
-rwxrwxrwx 1 www-data www-data 405 Feb 6 2020 index.php
-rwxrwxrwx 1 www-data www-data 19915 Feb 21 10:51 license.txt
-rwxrwxrwx 1 www-data www-data 7409 Feb 21 10:51 readme.html
-rwxrwxrwx 1 www-data www-data 7387 Feb 13 2024 wp-activate.php
drwxrwxrwx 9 www-data www-data 4096 Sep 10 11:23 wp-content
-rwxrwxrwx 1 www-data www-data 351 Feb 6 2020 wp-blog-header.php
-rwxrwxrwx 1 www-data www-data 2323 Jun 14 2023 wp-comments-post.php
-rwxrwxrwx 1 www-data www-data 3017 Sep 30 12:02 wp-config.php
-rwxrwxrwx 1 www-data www-data 3336 Feb 21 10:51 wp-config-sample.php
drwxrwxrwx 6 www-data www-data 4096 Feb 21 22:27 wp-core
-rwxrwxrwx 1 www-data www-data 5617 Feb 21 10:51 wp-cron.php
drwxrwxrwx 30 www-data www-data 12288 Feb 21 10:51 wp-includes
-rwxrwxrwx 1 www-data www-data 2502 Nov 26 2022 wp-links-opml.php
-rwxrwxrwx 1 www-data www-data 3937 Mar 11 2024 wp-load.php
-rwxrwxrwx 1 www-data www-data 51367 Feb 21 10:51 wp-login.php
-rwxrwxrwx 1 www-data www-data 8543 Feb 21 10:51 wp-mail.php
-rwxrwxrwx 1 www-data www-data 29032 Feb 21 10:51 wp-settings.php
-rwxrwxrwx 1 www-data www-data 34385 Jun 19 2023 wp-signup.php
-rwxrwxrwx 1 www-data www-data 5102 Feb 21 10:51 wp-trackback.php
-rwxrwxrwx 1 www-data www-data 3246 Mar 2 2024 xmlrpc.php
debian@debian:~$
```

```
File Actions Edit View Help
GNU nano 7.2
// ** Database settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress' );

/** Database username */
define( 'DB_USER', 'wordpressuser' );

/** Database password */
define( 'DB_PASSWORD', '123456' );

/** Database hostname */
define( 'DB_HOST', 'localhost' );

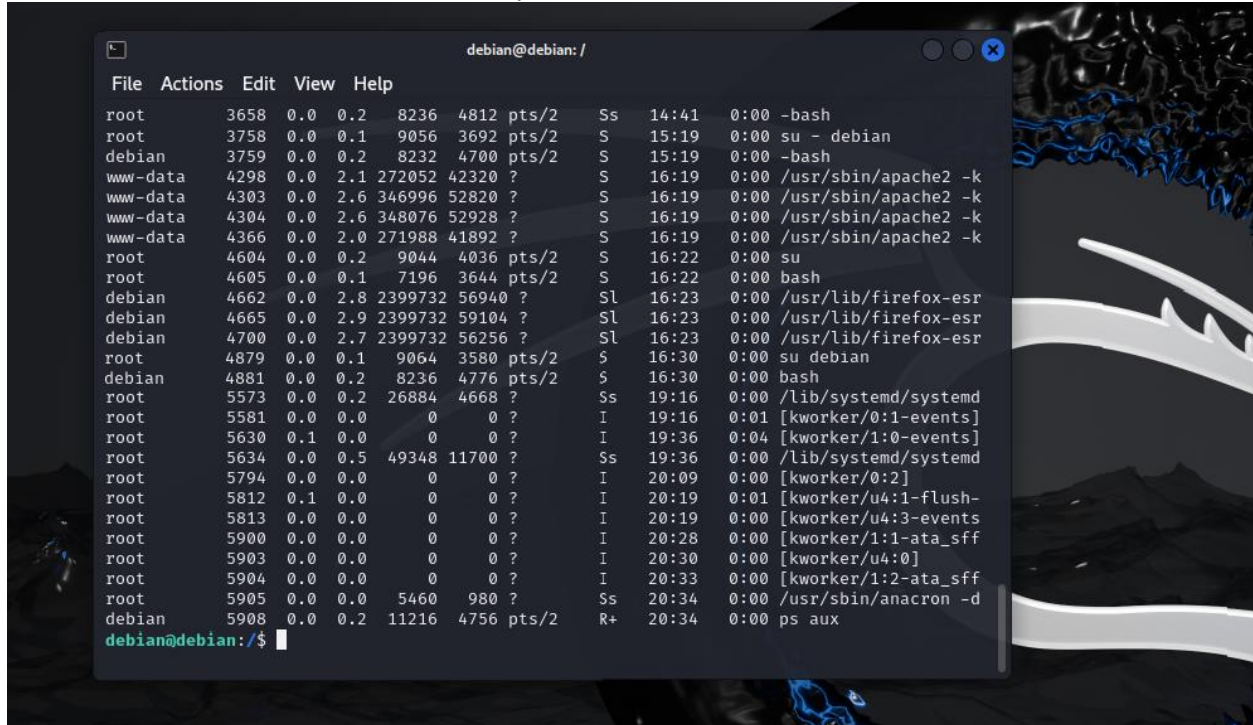
/** Database charset to use in creating database tables. */
define( 'DB_CHARSET', 'utf8' );

/** The database collate type. Don't change this if in doubt. */
define( 'DB_COLLATE', '' );

/**#@+
 * Authentication unique keys and salts.
 *
 * Change these to different unique phrases! You can generate these using
 * the {@link https://api.wordpress.org/secret-key/1.1/salt/ WordPress.org secret-key service}.
 *
 * You can change these at any point in time to invalidate all existing cookies.
 * This will force all users to have to log in again.
 *
 * @since 2.6.0
 */
define( 'AUTH_KEY', 'put your unique phrase here' );
define( 'SECURE_AUTH_KEY', 'put your unique phrase here' );
define( 'LOGGED_IN_KEY', 'put your unique phrase here' );
define( 'NONCE_KEY', 'put your unique phrase here' );
define( 'AUTH_SALT', 'put your unique phrase here' );
define( 'SECURE_AUTH_SALT', 'put your unique phrase here' );
define( 'LOGGED_IN_SALT', 'put your unique phrase here' );
define( 'NONCE_SALT', 'put your unique phrase here' );

/**#@-*/
```

Se continuó analizando los procesos en ejecución con `ps aux` para detectar si algún proceso estaba consumiendo más recursos de lo habitual, y no se detectó nada fuera de lo habitual.



```
File Actions Edit View Help
root      3658  0.0  0.2  8236  4812 pts/2    Ss   14:41   0:00 -bash
root      3758  0.0  0.1   9056   3692 pts/2    S    15:19   0:00 su - debian
debian    3759  0.0  0.2   8232   4700 pts/2    S    15:19   0:00 -bash
www-data  4298  0.0  2.1 272052 42320 ?        S    16:19   0:00 /usr/sbin/apache2 -k
www-data  4303  0.0  2.6 346996 52820 ?        S    16:19   0:00 /usr/sbin/apache2 -k
www-data  4304  0.0  2.6 348076 52928 ?        S    16:19   0:00 /usr/sbin/apache2 -k
www-data  4366  0.0  2.0 271988 41892 ?        S    16:19   0:00 /usr/sbin/apache2 -k
root      4604  0.0  0.2   9044   4036 pts/2    S    16:22   0:00 su
root      4605  0.0  0.1   7196   3644 pts/2    S    16:22   0:00 bash
debian    4662  0.0  2.8 2399732 56940 ?        Sl   16:23   0:00 /usr/lib/firefox-esr
debian    4665  0.0  2.9 2399732 59104 ?        Sl   16:23   0:00 /usr/lib/firefox-esr
debian    4700  0.0  2.7 2399732 56256 ?        Sl   16:23   0:00 /usr/lib/firefox-esr
root      4879  0.0  0.1   9064   3580 pts/2    S    16:30   0:00 su debian
debian    4881  0.0  0.2   8236   4776 pts/2    S    16:30   0:00 bash
root      5573  0.0  0.2  26884   4668 ?        Ss   19:16   0:00 /lib/systemd/systemd
root      5581  0.0  0.0      0      0 ?        I    19:16   0:01 [kworker/0:1-events]
root      5630  0.1  0.0      0      0 ?        I    19:36   0:04 [kworker/1:0-events]
root      5634  0.0  0.5  49348  11700 ?        Ss   19:36   0:00 /lib/systemd/systemd
root      5794  0.0  0.0      0      0 ?        I    20:09   0:00 [kworker/0:2]
root      5812  0.1  0.0      0      0 ?        I    20:19   0:01 [kworker/u4:1-flush-
root      5813  0.0  0.0      0      0 ?        I    20:19   0:00 [kworker/u4:3-events
root      5900  0.0  0.0      0      0 ?        I    20:28   0:00 [kworker/1:1-ata_sff
root      5903  0.0  0.0      0      0 ?        I    20:30   0:00 [kworker/u4:0]
root      5904  0.0  0.0      0      0 ?        I    20:33   0:00 [kworker/1:2-ata_sff
root      5905  0.0  0.0   5460    980 ?        Ss   20:34   0:00 /usr/sbin/anacron -d
debian    5908  0.0  0.2  11216   4756 pts/2    R+   20:34   0:00 ps aux
debian@debian:/$
```

Una de las debilidades más alarmantes fue la mala configuración de permisos excesivos en el archivo `wp-config.php`, por lo cual se procedió a revisar la base de datos y las configuraciones de los usuarios. Allí se detectó el usuario "user", un usuario poco habitual.

```
-rwxrwxrwx 1 www-data www-data 3246 Mar 2 2024 xmlrpc.php
debian@debian:/var/www/html$ sudo mysql -u root -p
[sudo] password for debian:
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 143
Server version: 10.11.6-MariaDB-0+deb12u1 Debian 12

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> SELECT User FROM mysql.user;
+-----+
| User          |
+-----+
| mariadb.sys   |
| mysql         |
| root          |
| user          |
| wordpressuser |
+-----+
5 rows in set (0.045 sec)

MariaDB [(none)]>
```

Se revisaron las configuraciones de todos los usuarios, y como se aprecia en las evidencias de mariadb.sys (que tenía configuraciones adecuadas), los usuarios mysql, wordpressuser y user tenían configuraciones demasiado permisivas. Por ende, tenían vulnerabilidades de configuración importantes. El siguiente paso fue revisar la fortaleza de esas contraseñas.

```
1 row in set (0.010 sec)

MariaDB [(none)]> SHOW GRANTS FOR 'mariadb.sys'@'localhost';
+-----+
| Grants for mariadb.sys@localhost |
+-----+
| GRANT USAGE ON *.* TO `mariadb.sys`@`localhost` |
| GRANT SELECT, DELETE ON `mysql`.`global_priv` TO `mariadb.sys`@`localhost` |
+-----+
2 rows in set (0.001 sec)

MariaDB [(none)]>
```



```
Linux-2024.4-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
1 2 3 4

debian@debian: /var/www/html
File Actions Edit View Help
| GRANT SELECT, DELETE ON `mysql`.`global_priv` TO `mariadb.sys`@`localhost` |
+-----+
2 rows in set (0.001 sec)

MariaDB [(none)]> SHOW GRANTS FOR 'mysql'@'localhost';
+-----+
| Grants for mysql@localhost |
+-----+
| GRANT ALL PRIVILEGES ON *.* TO `mysql`@`localhost` IDENTIFIED VIA mysql_native_password USING 'invalid' OR unix_socket WITH GRANT OPTION |
| GRANT PROXY ON ''@`%` TO 'mysql'@'localhost' WITH GRANT OPTION |
+-----+
```

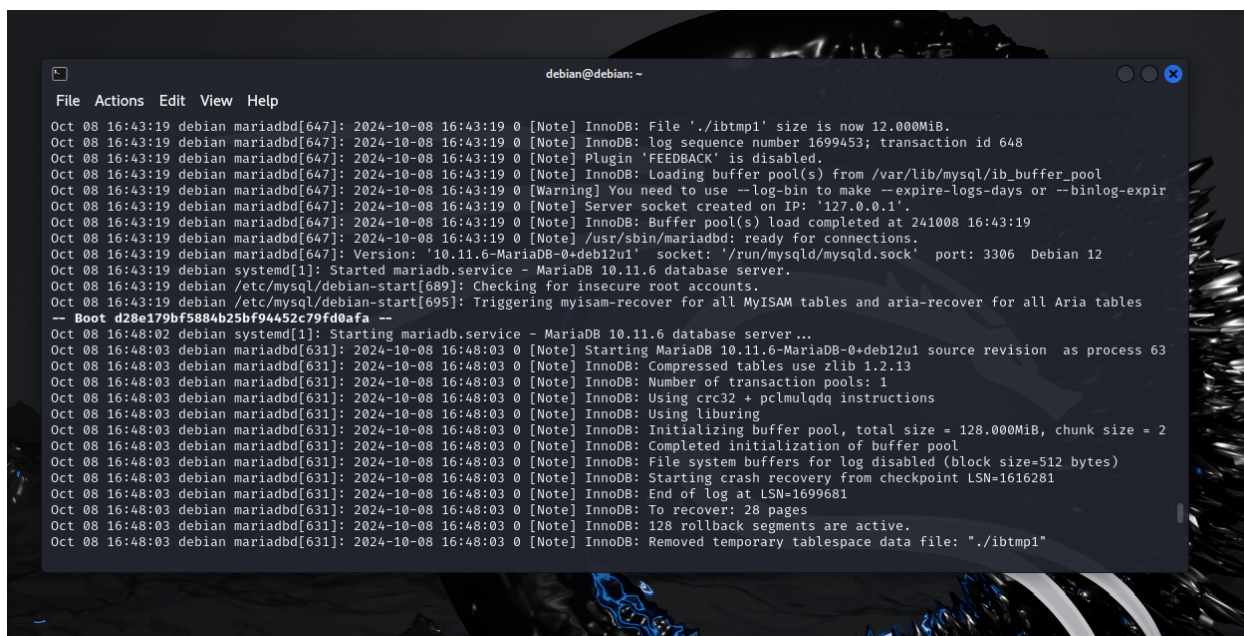
```
2 rows in set (0.001 sec)

MariaDB [(none)]> SHOW GRANTS FOR 'root'@'localhost';
+-----+
| Grants for root@localhost |
+-----+
| GRANT ALL PRIVILEGES ON *.* TO `root`@`localhost` IDENTIFIED VIA mysql_native_password USING '*6BB4837EB74329105EE4568DDA7DC67ED2CA2AD9' OR unix_socket WITH GRANT OPTION |
| GRANT PROXY ON ''@`%` TO 'root'@'localhost' WITH GRANT OPTION |
+-----+
```

```
MariaDB [(none)]> SHOW GRANTS FOR 'wordpressuser'@'localhost';
+-----+
| Grants for wordpressuser@localhost |
+-----+
| GRANT USAGE ON *.* TO `wordpressuser`@`localhost` IDENTIFIED BY PASSWORD '*6BB4837EB74329105EE4568DDA7DC67ED2CA2AD9' |
| GRANT ALL PRIVILEGES ON `wordpress`.* TO `wordpressuser`@`localhost` |
+-----+
2 rows in set (0.000 sec)

MariaDB [(none)]> 
```

Se revisaron los logs de MariaDB, y no se detectó nada relevante. Sus registros binarios no estaban habilitados, lo cual significa que, si se tiene algún problema, MariaDB no se podrá recuperar de un incidente.



```
debian@debian: ~
File Actions Edit View Help
Oct 08 16:43:19 debian mariadb[647]: 2024-10-08 16:43:19 0 [Note] InnoDB: File './ibtmp1' size is now 12.000MiB.
Oct 08 16:43:19 debian mariadb[647]: 2024-10-08 16:43:19 0 [Note] InnoDB: log sequence number 1699453; transaction id 648
Oct 08 16:43:19 debian mariadb[647]: 2024-10-08 16:43:19 0 [Note] Plugin 'FEEDBACK' is disabled.
Oct 08 16:43:19 debian mariadb[647]: 2024-10-08 16:43:19 0 [Note] InnoDB: Loading buffer pool(s) from /var/lib/mysql/ib_buffer_pool
Oct 08 16:43:19 debian mariadb[647]: 2024-10-08 16:43:19 0 [Warning] You need to use --log-bin to make --expire-logs-days or --binlog-expir
Oct 08 16:43:19 debian mariadb[647]: 2024-10-08 16:43:19 0 [Note] Server socket created on IP: '127.0.0.1'.
Oct 08 16:43:19 debian mariadb[647]: 2024-10-08 16:43:19 0 [Note] InnoDB: Buffer pool(s) load completed at 241008 16:43:19
Oct 08 16:43:19 debian mariadb[647]: 2024-10-08 16:43:19 0 [Note] /usr/sbin/mariadb: ready for connections.
Oct 08 16:43:19 debian mariadb[647]: Version: '10.11.6-MariaDB-0+deb12u1' socket: '/run/mysqld/mysqld.sock' port: 3306 Debian 12
Oct 08 16:43:19 debian systemd[1]: Started mariadb.service - MariaDB 10.11.6 database server.
Oct 08 16:43:19 debian /etc/mysql/debian-start[689]: Checking for insecure root accounts.
Oct 08 16:43:19 debian /etc/mysql/debian-start[695]: Triggering myisam-recover for all MyISAM tables and aria-recover for all Aria tables
-- Boot d28e179bf5884b25bf94452c79fd0afa --
Oct 08 16:48:02 debian systemd[1]: Starting mariadb.service - MariaDB 10.11.6 database server ...
Oct 08 16:48:03 debian mariadb[631]: 2024-10-08 16:48:03 0 [Note] Starting MariaDB 10.11.6-MariaDB-0+deb12u1 source revision as process 63
Oct 08 16:48:03 debian mariadb[631]: 2024-10-08 16:48:03 0 [Note] InnoDB: Compressed tables use zlib 1.2.13
Oct 08 16:48:03 debian mariadb[631]: 2024-10-08 16:48:03 0 [Note] InnoDB: Number of transaction pools: 1
Oct 08 16:48:03 debian mariadb[631]: 2024-10-08 16:48:03 0 [Note] InnoDB: Using crc32 + pclmulqdq instructions
Oct 08 16:48:03 debian mariadb[631]: 2024-10-08 16:48:03 0 [Note] InnoDB: Using liburing
Oct 08 16:48:03 debian mariadb[631]: 2024-10-08 16:48:03 0 [Note] InnoDB: Initializing buffer pool, total size = 128.000MiB, chunk size = 2
Oct 08 16:48:03 debian mariadb[631]: 2024-10-08 16:48:03 0 [Note] InnoDB: Completed initialization of buffer pool
Oct 08 16:48:03 debian mariadb[631]: 2024-10-08 16:48:03 0 [Note] InnoDB: File system buffers for log disabled (block size=512 bytes)
Oct 08 16:48:03 debian mariadb[631]: 2024-10-08 16:48:03 0 [Note] InnoDB: Starting crash recovery from checkpoint LSN=1616281
Oct 08 16:48:03 debian mariadb[631]: 2024-10-08 16:48:03 0 [Note] InnoDB: End of log at LSN=1699681
Oct 08 16:48:03 debian mariadb[631]: 2024-10-08 16:48:03 0 [Note] InnoDB: To recover: 28 pages
Oct 08 16:48:03 debian mariadb[631]: 2024-10-08 16:48:03 0 [Note] InnoDB: 128 rollback segments are active.
Oct 08 16:48:03 debian mariadb[631]: 2024-10-08 16:48:03 0 [Note] InnoDB: Removed temporary tablespace data file: './ibtmp1'
```

Luego de realizar el análisis del sistema, las configuraciones y los procesos en ejecución, se procedió a instalar chkrootkit y rkhunter para buscar rootkits y otro malware.

chkrootkit arrojó una lista de archivos que se debían investigar, los cuales se revisaron y no contenían nada malicioso. También se generó una advertencia que fue la siguiente:

WARNING: Output from ifpromisc:

lo: not promisc and no packet sniffer sockets

enp0s3: PACKET SNIFFER(/usr/sbin/NetworkManager[452], /usr/sbin/NetworkManager[452])

La advertencia se refería a que la interfaz enp0s3 tenía el modo promiscuo activado debido a tcpdump, lo que significa que estaba aceptando todos los paquetes de datos de la red, lo cual no es lo indicado, ya que puede aceptar contenido malicioso.

```
File Actions Edit View Help
Get:3 http://security.debian.org/debian-security bookworm-security InRelease [48.0 kB]
Fetched 103 kB in 2s (42.1 kB/s)
Reading package lists... Done
debian@debian:~$ sudo apt-get install chkrootkit rkhunter
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following package was automatically installed and is no longer required:
  linux-image-6.1.0-22-amd64
Use 'sudo apt autoremove' to remove it.
The following additional packages will be installed:
  binutils binutils-common binutils-x86-64-linux-gnu exim4-base exim4-config exim4-daemon-light fonts-lato gssasl-common guile-3.0-libs
  libbinutils libctf-nobfd0 libctf0 libgcc1 libgnutls-dane0 libgnutls30 libgprofng0 libgssasl18 libgssglue1 libjs-jquery libmailutils9
  libntlm0 libpq5 libruby libruby3.1 libunbound8 libyaml-0-2 mailutils mailutils-common rake ruby ruby-net-telnet ruby-rubygems ruby-sdbm
  ruby-webrick ruby-xmlrpc ruby3.1 rubygems-integration unhide unhide.rb
Suggested packages:
  binutils-doc exim4-doc-html | exim4-doc-info eximon4 spf-tools-perl swaks gnutls-bin mailutils-mh mailutils-doc powermtmt-base ri
  ruby-dev bundler
The following NEW packages will be installed:
  binutils binutils-common binutils-x86-64-linux-gnu chkrootkit exim4-base exim4-config exim4-daemon-light fonts-lato gssasl-common
  guile-3.0-libs libbinutils libctf-nobfd0 libctf0 libgcc1 libgnutls-dane0 libgprofng0 libgssasl18 libgssglue1 libjs-jquery libmailutils9
  libntlm0 libpq5 libruby libruby3.1 libunbound8 libyaml-0-2 mailutils mailutils-common rake rkhunter ruby ruby-net-telnet ruby-rubygems
  ruby-sdbm ruby-webrick ruby-xmlrpc ruby3.1 rubygems-integration unhide unhide.rb
The following packages will be upgraded:
  libgnutls30
1 upgraded, 40 newly installed, 0 to remove and 148 not upgraded.
Need to get 30.9 MB of archives.
```

```
File Actions Edit View Help
Processing triggers for rkhunter (1.4.6-11) ...
[ Rootkit Hunter version 1.4.6 ]
File updated: searched for 181 files, found 144
debian@debian:~$ sudo chkrootkit
ROOTDIR is '/'
Checking 'amd' ... not found
Checking 'basename' ... not infected
Checking 'biff' ... not found
Checking 'chfn' ... not infected
Checking 'chsh' ... not infected
Checking 'cron' ... not infected
Checking 'crontab' ... not infected
Checking 'date' ... not infected
Checking 'du' ... not infected
Checking 'dirname' ... not infected
Checking 'echo' ... not infected
Checking 'egrep' ... not infected
Checking 'env' ... not infected
Checking 'find' ... not infected
Checking 'fingerd' ... not found
Checking 'gpm' ... not found
Checking 'grep' ... not infected
Checking 'hdparm' ... not found
Checking 'su' ... not infected
Checking 'ifconfig' ... not infected
Checking 'inetd' ... not infected
Checking 'inetdconf' ... not found
```

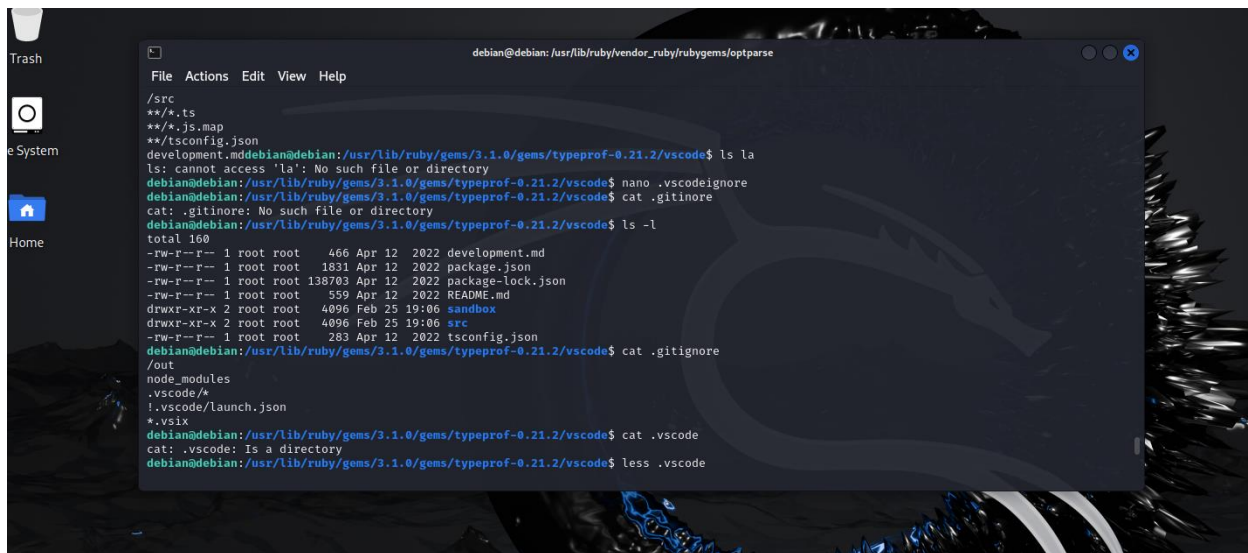
```
Searching for RSHA rootkit ... not found
Searching for RH-Sharp rootkit ... not found
Searching for Ambient (ark) rootkit ... not found
Searching for suspicious files and dirs ... WARNING

WARNING: The following suspicious files and directories were found:
/usr/lib/ruby/gems/3.1.0/gems/typeprof-0.21.2/vscode/.vscodeignore
/usr/lib/ruby/gems/3.1.0/gems/typeprof-0.21.2/vscode/.gitignore
/usr/lib/ruby/gems/3.1.0/gems/typeprof-0.21.2/vscode/.vscode
/usr/lib/ruby/vendor_ruby/rubygems/ssl_certs/.document
/usr/lib/ruby/vendor_ruby/rubygems/tsort/.document
/usr/lib/ruby/vendor_ruby/rubygems/optparse/.document
/usr/lib/libreoffice/share/.registry
Searching for LDD Worms ... not found
```

```
Searching for hidden directories using chkdirs... not found
Checking `lkm' ... finished
Checking `rexedcs' ... not found
Checking `sniffer' ... WARNING

WARNING: Output from ifpromisc:
lo: not promisc and no packet sniffer sockets
enp0s3: PACKET SNIFFER(/usr/sbin/NetworkManager[452], /usr/sbin/NetworkManager[452])

Checking `w55808' ... not found
Checking `wtcd' ... not found
Checking `scalper' ... not found
```



```
debian@debian: /usr/lib/ruby/vendor_ruby/rubygems/optparse
File Actions Edit View Help
/src
**/*.ts
**/*.js.map
**/tsconfig.json
development.mddebian@debian:/usr/lib/ruby/gems/3.1.0/gems/typeprof-0.21.2/vscode$ ls -la
ls: cannot access 'la': No such file or directory
debian@debian:/usr/lib/ruby/gems/3.1.0/gems/typeprof-0.21.2/vscode$ nano .vscodeignore
debian@debian:/usr/lib/ruby/gems/3.1.0/gems/typeprof-0.21.2/vscode$ cat .gitignore
cat: .gitignore: No such file or directory
debian@debian:/usr/lib/ruby/gems/3.1.0/gems/typeprof-0.21.2/vscode$ ls -l
total 160
-rw-r--r-- 1 root root 466 Apr 12 2022 development.md
-rw-r--r-- 1 root root 1831 Apr 12 2022 package.json
-rw-r--r-- 1 root root 138703 Apr 12 2022 package-lock.json
-rw-r--r-- 1 root root 559 Apr 12 2022 README.md
drwxr-xr-x 2 root root 4096 Feb 25 19:06 sandbox
drwxr-xr-x 2 root root 4096 Feb 25 19:06 src
-rw-r--r-- 1 root root 283 Apr 12 2022 tsconfig.json
debian@debian:/usr/lib/ruby/gems/3.1.0/gems/typeprof-0.21.2/vscode$ cat .gitignore
/out
node_modules
.vscodex/*
!.vscode/launch.json
*.vsix
debian@debian:/usr/lib/ruby/gems/3.1.0/gems/typeprof-0.21.2/vscode$ cat .vscode
cat: .vscode: Is a directory
debian@debian:/usr/lib/ruby/gems/3.1.0/gems/typeprof-0.21.2/vscode$ less .vscode
```

Se ejecutó rkhunter para detectar rootkits, y entre las cinco advertencias que se encontraron, se detectó que se podía acceder al usuario root directamente por SSH. Además, se identificaron tres archivos que posiblemente habían sido modificados y una posible afectación por segmentos de memoria compartida.


```
File Actions Edit View Help
Unpacking libcurl3-gnutls:amd64 (7.88.1-10+deb12u8) over (7.88.1-10+deb12u7) ...
Setting up libcurl3-gnutls:amd64 (7.88.1-10+deb12u8) ...
Setting up libcurl4:amd64 (7.88.1-10+deb12u8) ...
Setting up curl (7.88.1-10+deb12u8) ...
Setting up rkhunter (1.4.6-11) ...
Processing triggers for man-db (2.11.2-2) ...
Processing triggers for libc-bin (2.36-9+deb12u8) ...
debian@debian:/$ sudo rkhunter --update
Invalid WEB_CMD configuration option: Relative pathname: "/bin/false"
debian@debian:/$ sudo rkhunter --check
[ Rootkit Hunter version 1.4.6 ]

Checking system commands ...

Performing 'strings' command checks
Checking 'strings' command [ OK ]

Performing 'shared libraries' checks
Checking for preloading variables [ None found ]
Checking for preloaded libraries [ None found ]
Checking LD_LIBRARY_PATH variable [ Not found ]

Performing file properties checks
Checking for prerequisites [ OK ]
/usr/sbin/adduser [ OK ]
/usr/sbin/chroot [ OK ]
/usr/sbin/cron [ OK ]
```

```
File Actions Edit View Help
Checking for system startup files [ Found ]
Checking system startup files for malware [ None found ]

Performing group and account checks
Checking for passwd file [ Found ]
Checking for root equivalent (UID 0) accounts [ None found ]
Checking for passwordless accounts [ None found ]
Checking for passwd file changes [ None found ]
Checking for group file changes [ None found ]
Checking root account shell history files [ OK ]

Performing system configuration file checks
Checking for an SSH configuration file [ Found ]
Checking if SSH root access is allowed [ Warning ]
Checking if SSH protocol v1 is allowed [ Not set ]
Checking for other suspicious configuration settings [ None found ]
Checking for a running system logging daemon [ Found ]
Checking for a system logging configuration file [ Found ]

Performing filesystem checks
Checking /dev for suspicious file types [ None found ]
Checking for hidden files and directories [ None found ]

[Press <ENTER> to continue]
```

Se revisaron los logs de FTP en busca de indicios de ataque o alguna otra anomalía, y no se evidenció nada relevante.

```

Wed Feb 26 21:19:15 2025 [pid 377264] CONNECT: Client "::ffff:192.168.1.43"
debian@debian:/$ sudo cat /etc/vsftpd.conf
[sudo] password for debian:
# Example config file /etc/vsftpd.conf
#
# The default compiled in settings are fairly paranoid. This sample file
# loosens things up a bit, to make the ftp daemon more usable.
# Please see vsftpd.conf.5 for all compiled in defaults.
#
# READ THIS: This example file is NOT an exhaustive list of vsftpd options.
# Please read the vsftpd.conf.5 manual page to get a full idea of vsftpd's
# capabilities.
#
# Run standalone? vsftpd can run either from an inetd or as a standalone
# daemon started from an initscript.
listen=NO
#
# This directive enables listening on IPv6 sockets. By default, listening
# on the IPv6 "any" address (:::) will accept connections from both IPv6
# and IPv4 clients. It is not necessary to listen on *both* IPv4 and IPv6
# sockets. If you want that (perhaps because you want to listen on specific
# addresses) then you must run two copies of vsftpd with two configuration
# files.

```

```

File Actions Edit View Help
# (default follows)
#chroot_list_file=/etc/vsftpd.chroot_list
#
# You may activate the "-R" option to the builtin ls. This is disabled by
# default to avoid remote users being able to cause excessive I/O on large
# sites. However, some broken FTP clients such as "ncftp" and "mirror" assume
# the presence of the "-R" option, so there is a strong case for enabling it.
#ls_recurse_enable=YES
#
# Customization
#
# Some of vsftpd's settings don't fit the filesystem layout by
# default.
#
# This option should be the name of a directory which is empty. Also, the
# directory should not be writable by the ftp user. This directory is used
# as a secure chroot() jail at times vsftpd does not require filesystem
# access.
secure_chroot_dir=/var/run/vsftpd/empty
#
# This string is the name of the PAM service vsftpd will use.
pam_service_name=vsftpd
#
# This option specifies the location of the RSA certificate to use for SSL
# encrypted connections.
rsa_cert_file=/etc/ssl/certs/ssl-cert-snakeoil.pem
rsa_private_key_file=/etc/ssl/private/ssl-cert-snakeoil.key

```

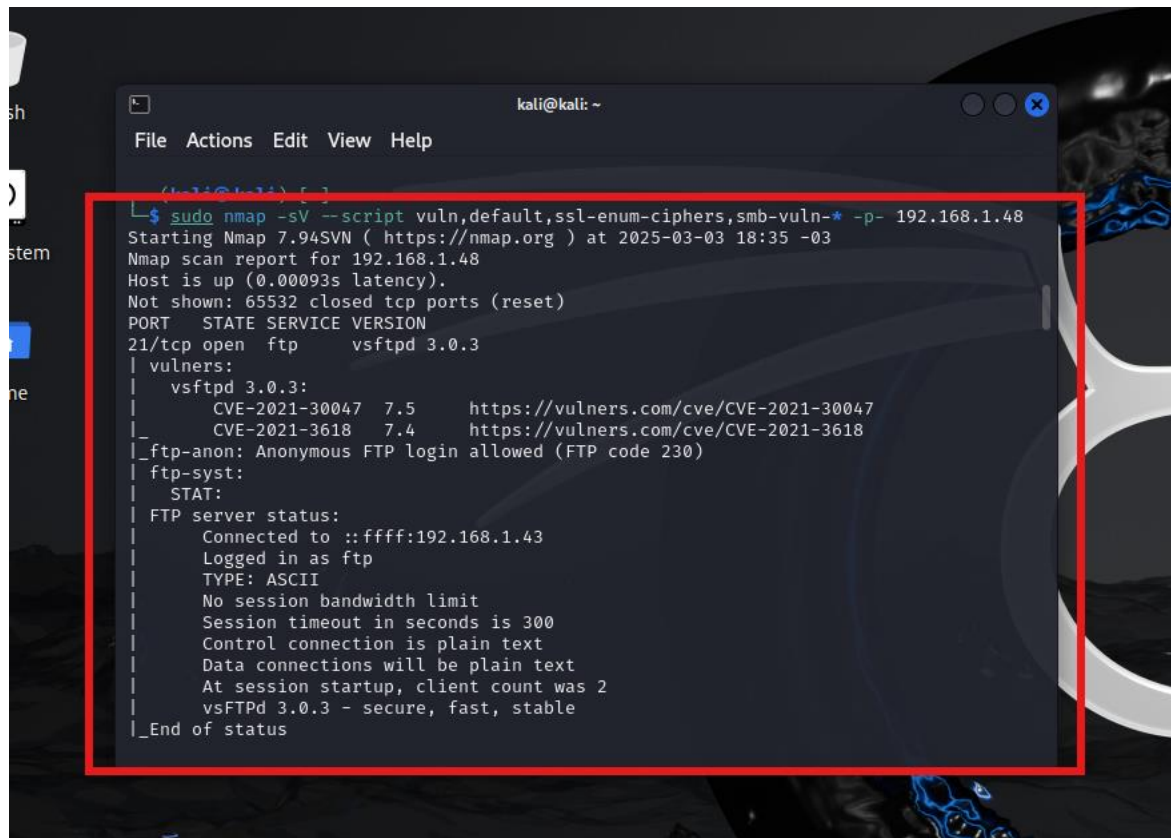
```

Fri Feb 21 10:51:11 2025 [pid 1586] [ftp] OK LOGIN: Client "::ffff:192.168.1.43", anon password "IEUser@"
Fri Feb 21 10:51:11 2025 [pid 1587] [ftp] OK LOGIN: Client "::ffff:192.168.1.43", anon password "IEUser@"
Fri Feb 21 10:51:15 2025 [pid 1624] CONNECT: Client "::ffff:192.168.1.43"
Fri Feb 21 10:51:15 2025 [pid 1626] CONNECT: Client "::ffff:192.168.1.43"
Fri Feb 21 10:51:15 2025 [pid 1628] CONNECT: Client "::ffff:192.168.1.43"
Wed Feb 26 21:19:15 2025 [pid 377264] CONNECT: Client "::ffff:192.168.1.43"
debian@debian:/$ sudo cat /var/log/vsftpd.log
Fri Feb 21 10:51:03 2025 [pid 1580] CONNECT: Client "::ffff:192.168.1.43"
Fri Feb 21 10:51:10 2025 [pid 1588] CONNECT: Client "::ffff:192.168.1.43"
Fri Feb 21 10:51:10 2025 [pid 1589] CONNECT: Client "::ffff:192.168.1.43"
Fri Feb 21 10:51:10 2025 [pid 1590] CONNECT: Client "::ffff:192.168.1.43"
Fri Feb 21 10:51:10 2025 [pid 1591] CONNECT: Client "::ffff:192.168.1.43"
Fri Feb 21 10:51:10 2025 [pid 1585] [ftp] OK LOGIN: Client "::ffff:192.168.1.43", anon password "IEUser@"
Fri Feb 21 10:51:11 2025 [pid 1586] [ftp] OK LOGIN: Client "::ffff:192.168.1.43", anon password "IEUser@"
Fri Feb 21 10:51:11 2025 [pid 1587] [ftp] OK LOGIN: Client "::ffff:192.168.1.43", anon password "IEUser@"
Fri Feb 21 10:51:15 2025 [pid 1624] CONNECT: Client "::ffff:192.168.1.43"
Fri Feb 21 10:51:15 2025 [pid 1626] CONNECT: Client "::ffff:192.168.1.43"
Fri Feb 21 10:51:15 2025 [pid 1628] CONNECT: Client "::ffff:192.168.1.43"
Wed Feb 26 21:19:15 2025 [pid 377264] CONNECT: Client "::ffff:192.168.1.43"
debian@debian:/$

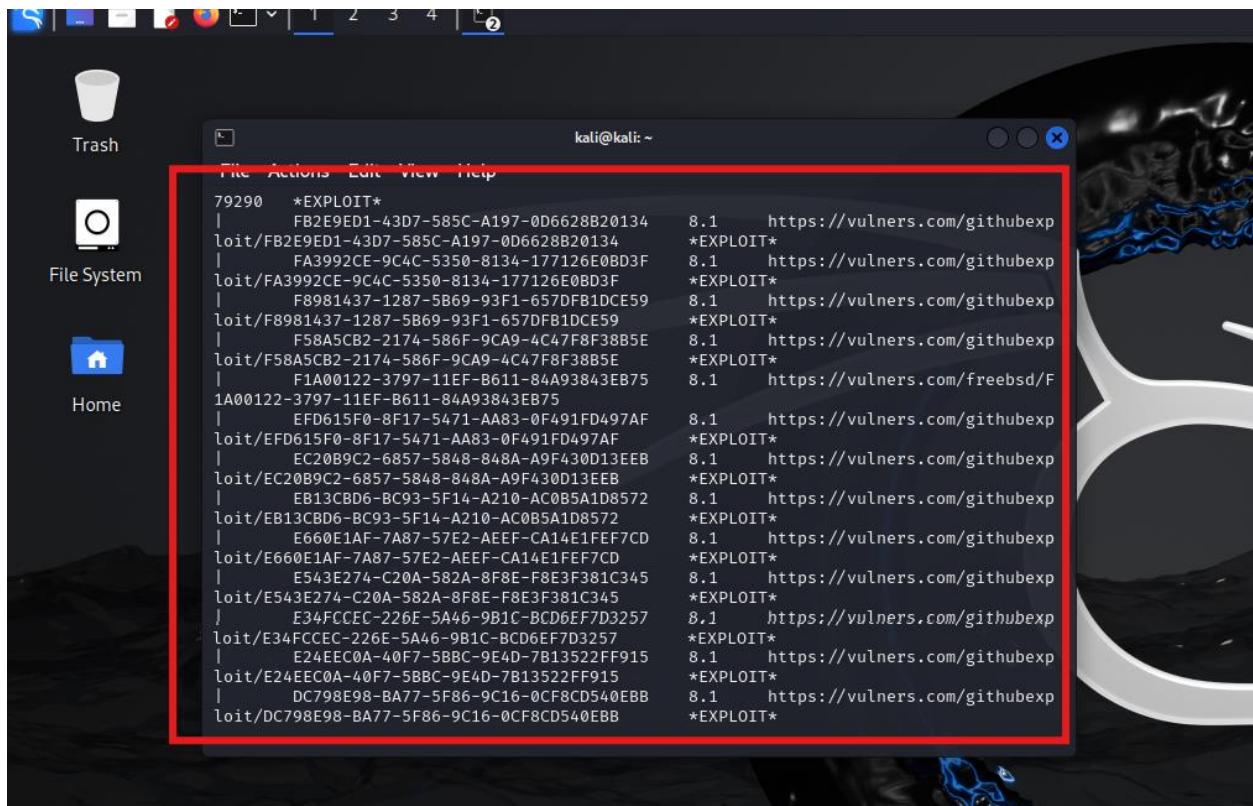
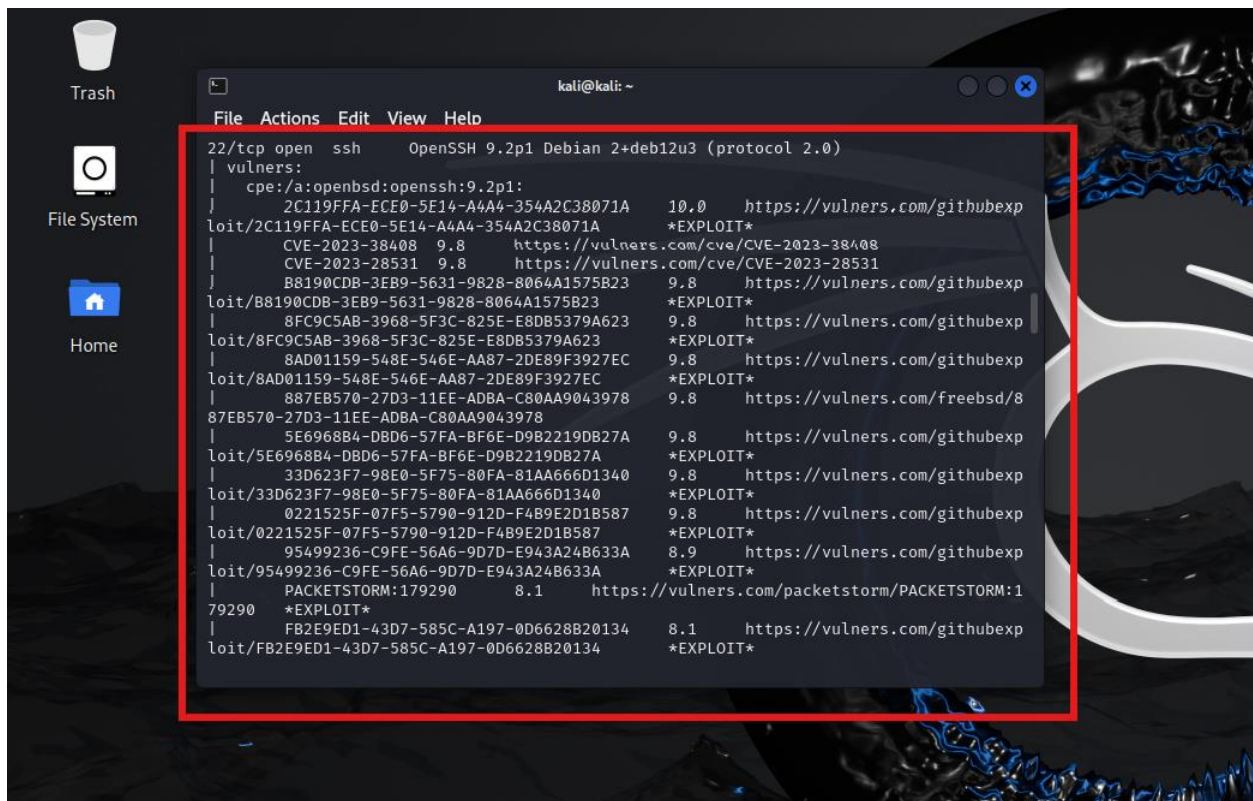
```

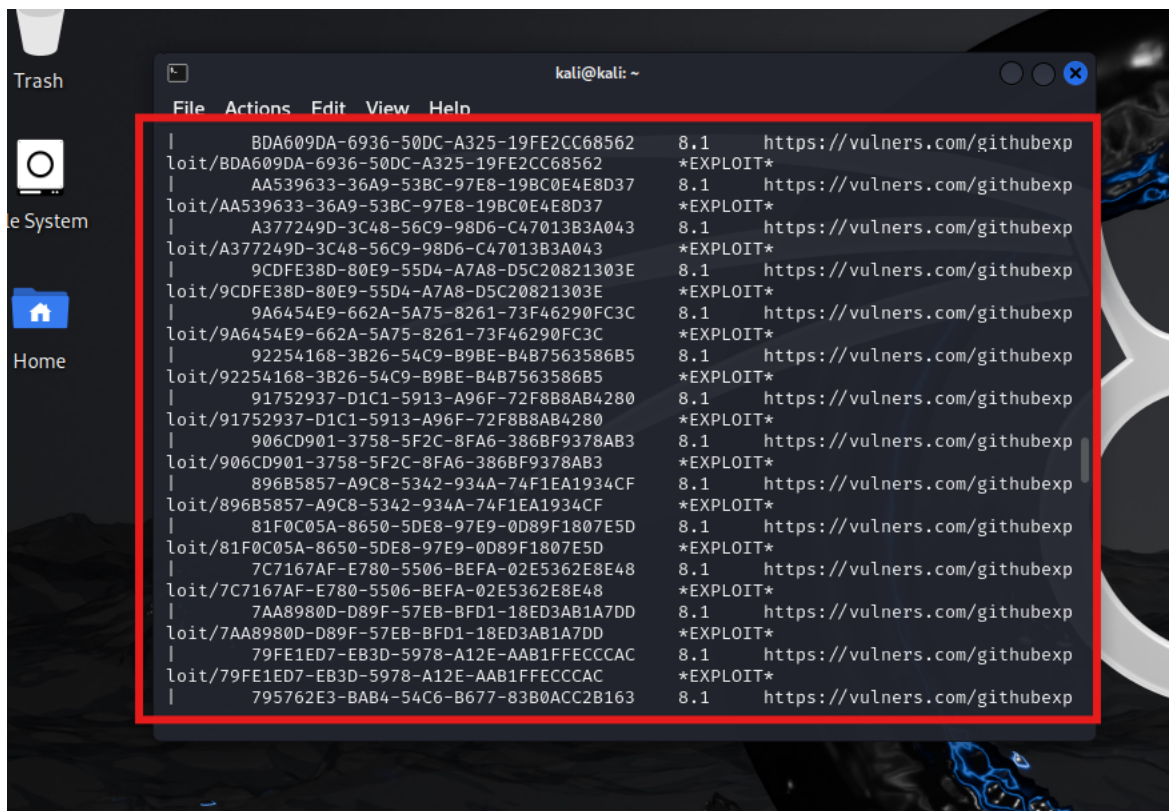
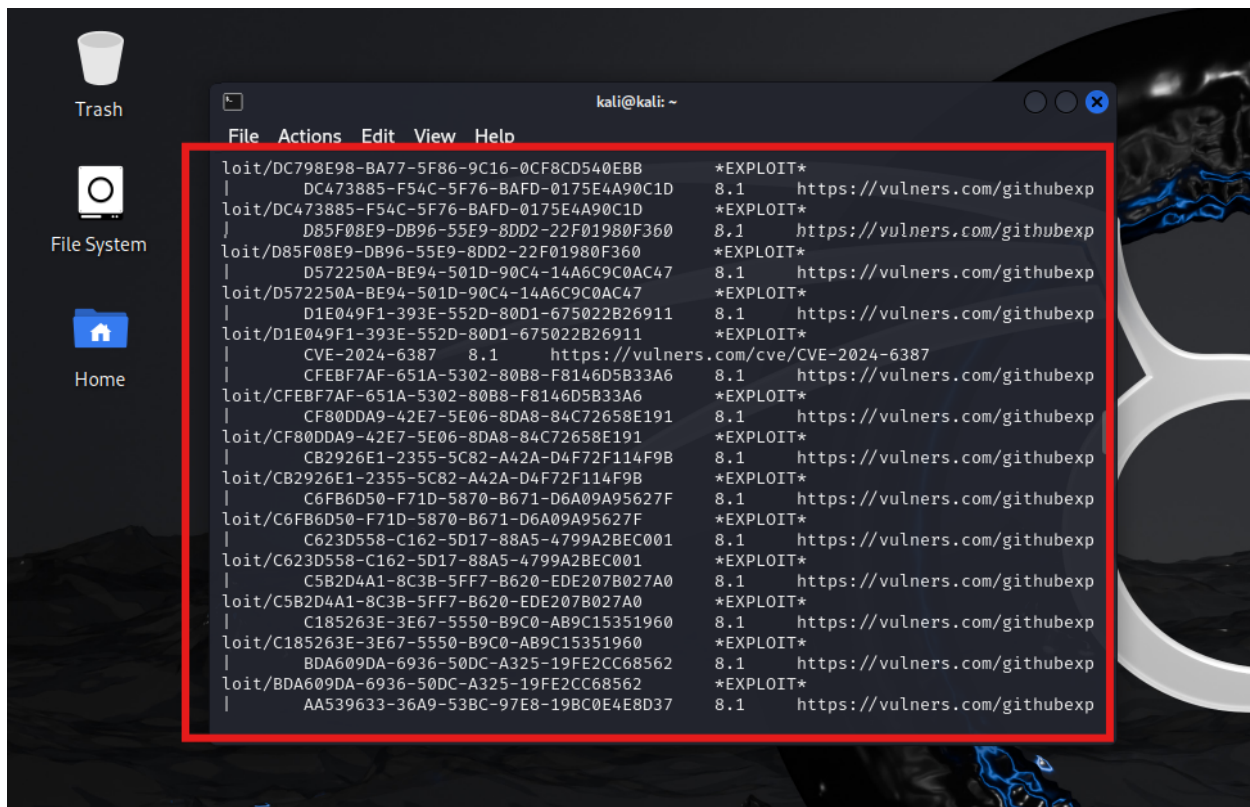
Se procedió a realizar un escaneo de vulnerabilidades con Nmap, que arrojó los siguientes hallazgos:

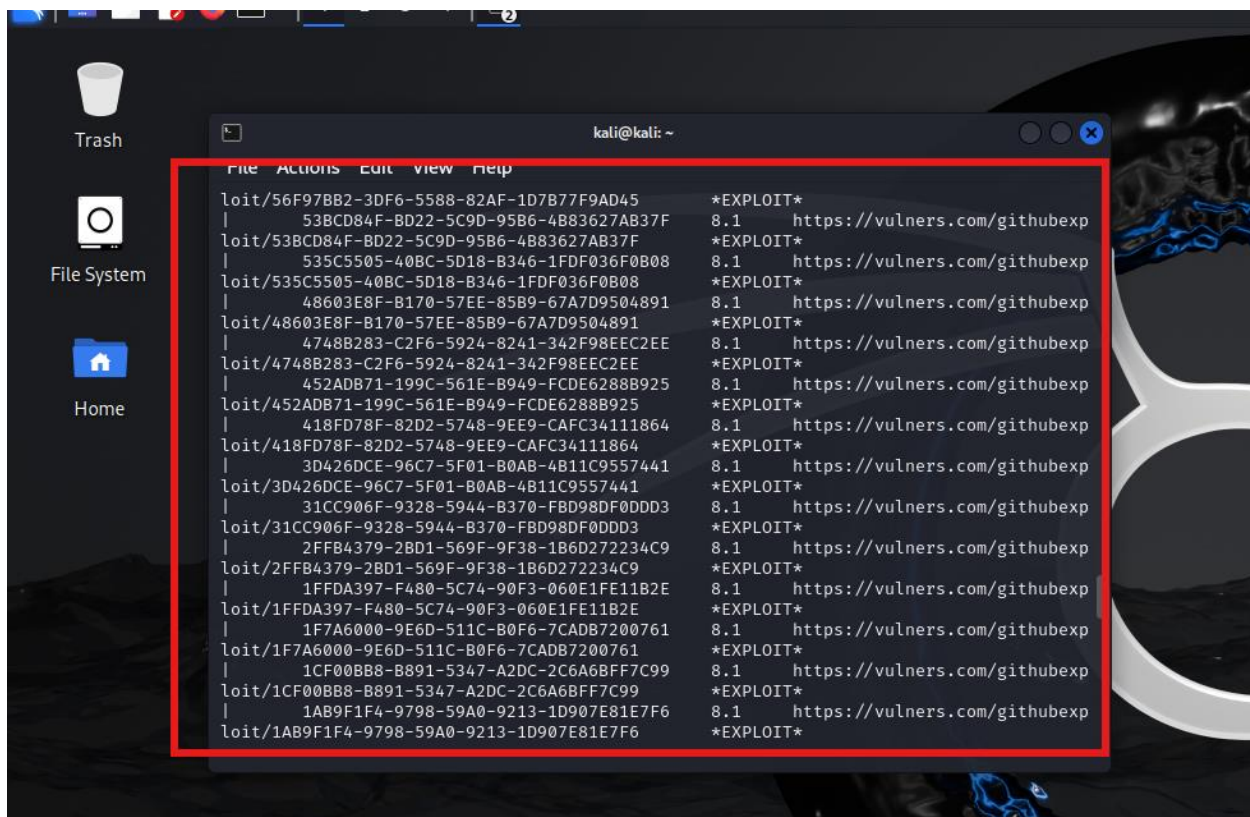
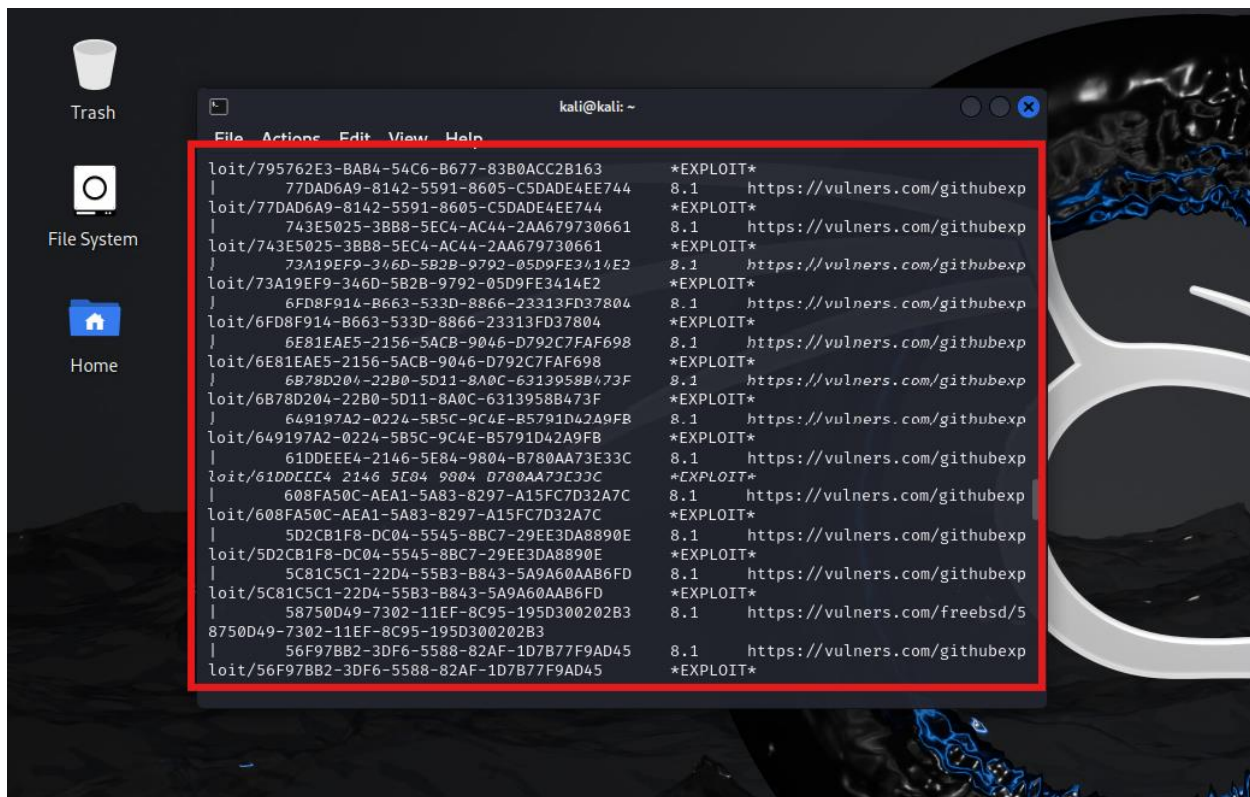
- Se identificaron puertos abiertos.
- Se detectaron vulnerabilidades y sus exploits para el servicio FTP (puerto 21), incluyendo dos vulnerabilidades importantes y la posibilidad de conexión anónima (sin usuario ni contraseña).
- Se encontró una cantidad muy alta de vulnerabilidades y sus exploits para el servicio SSH (puerto 22), algunas de ellas de alta severidad.
- Se detectaron posibles vulnerabilidades que requerían revisión en el servicio HTTP (puerto 80), incluyendo archivos y directorios a revisar, así como el servidor Apache y su versión.

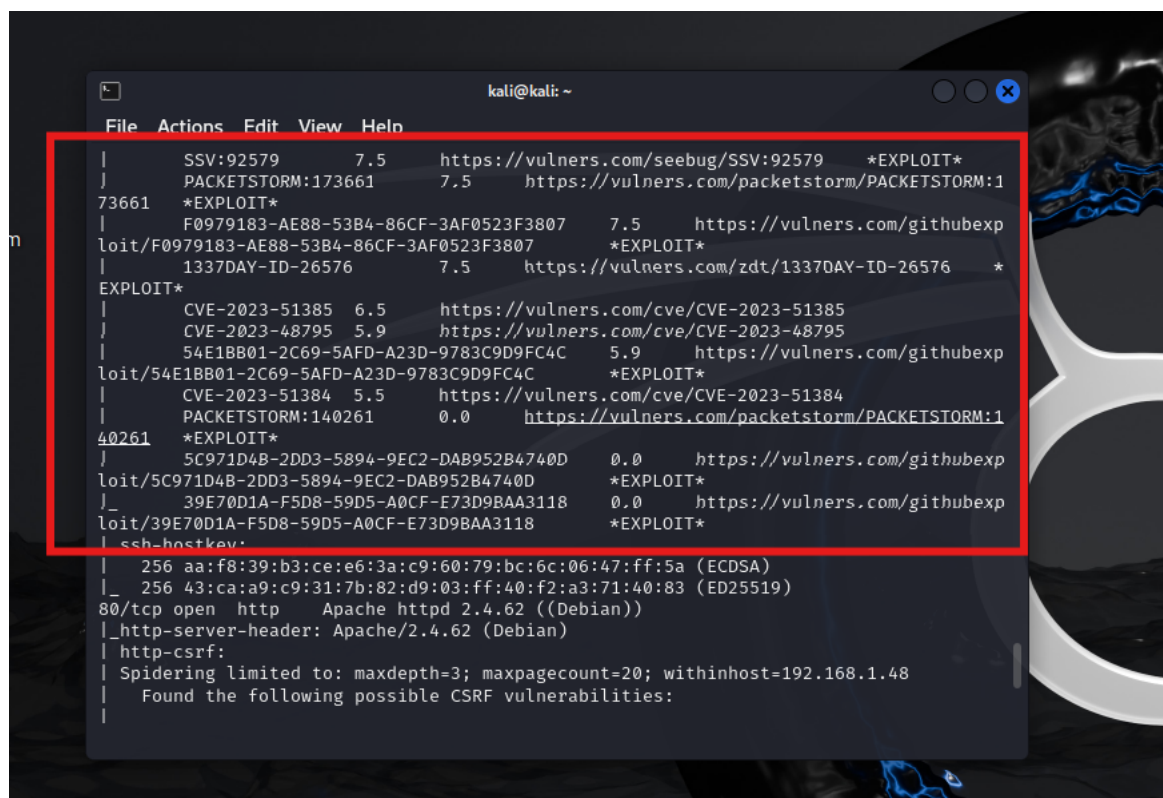
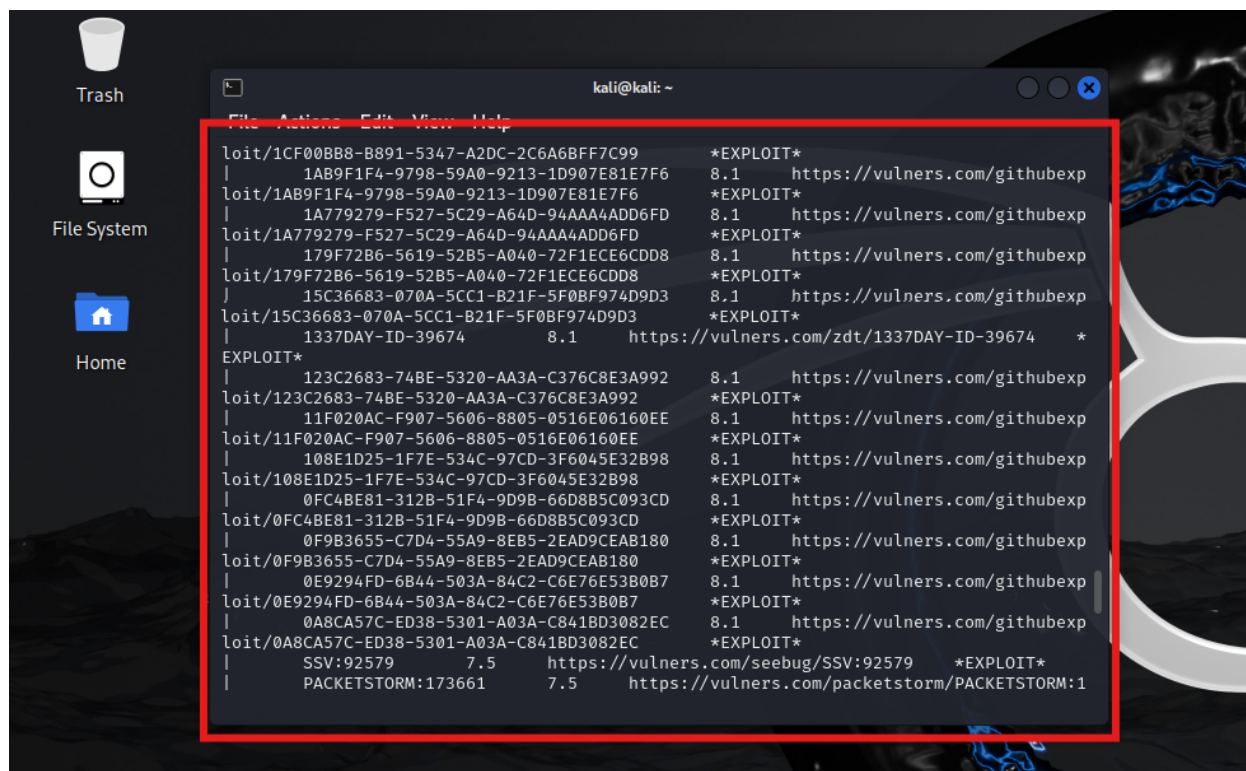


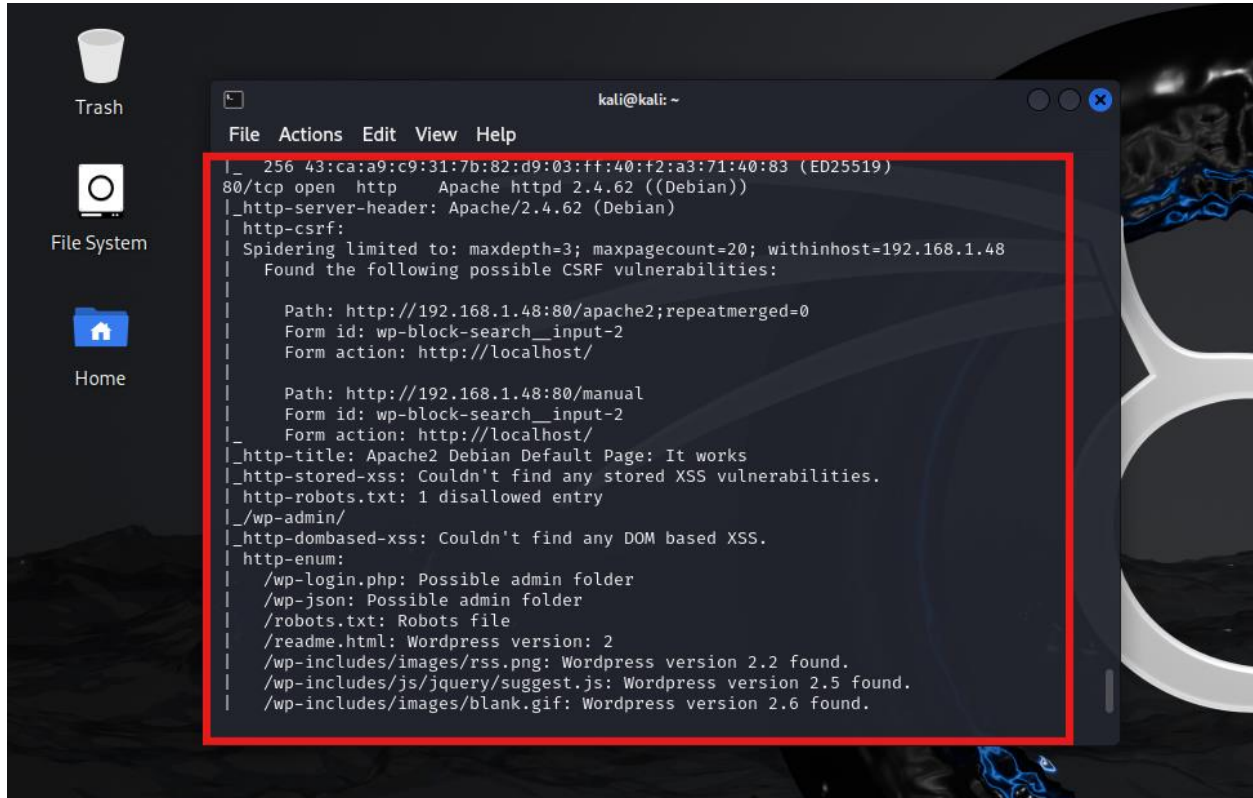
```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali) [ ]  
$ sudo nmap -sV --script vuln,default,ssl-enum-ciphers,smb-vuln-* -p- 192.168.1.48  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-03 18:35 -03  
Nmap scan report for 192.168.1.48  
Host is up (0.00093s latency).  
Not shown: 65532 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 3.0.3  
| vulners:  
|   vsftpd 3.0.3:  
|   CVE-2021-30047 7.5 https://vulners.com/cve/CVE-2021-30047  
|   CVE-2021-3618 7.4 https://vulners.com/cve/CVE-2021-3618  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
|ftp-syst:  
|  STAT:  
|  FTP server status:  
|  Connected to ::ffff:192.168.1.43  
|  Logged in as ftp  
|  TYPE: ASCII  
|  No session bandwidth limit  
|  Session timeout in seconds is 300  
|  Control connection is plain text  
|  Data connections will be plain text  
|  At session startup, client count was 2  
|  vsFTPd 3.0.3 - secure, fast, stable  
|_End of status
```



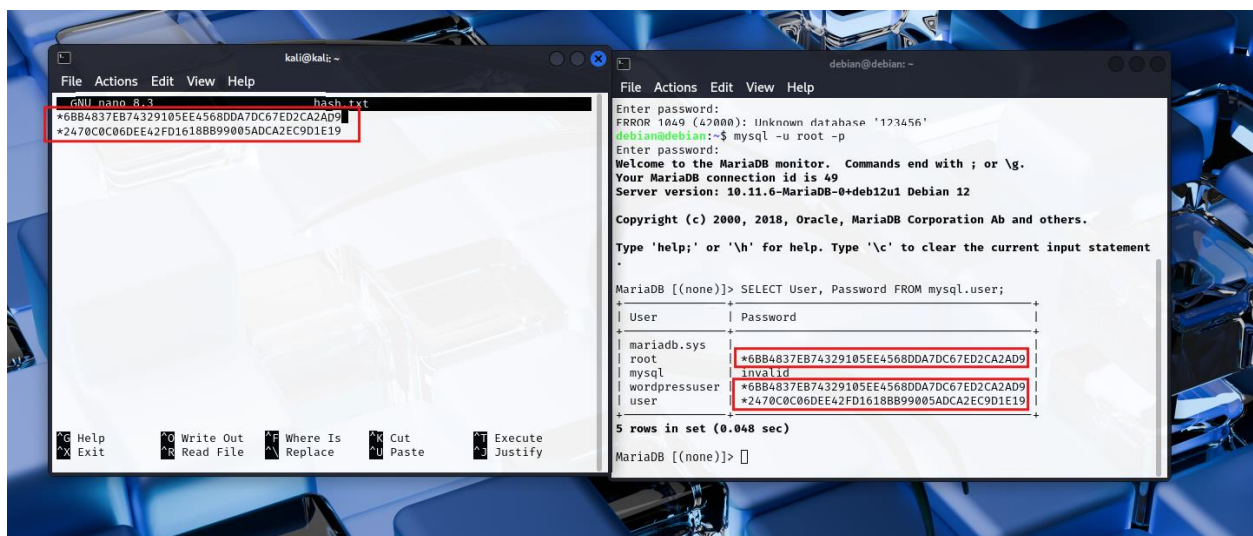


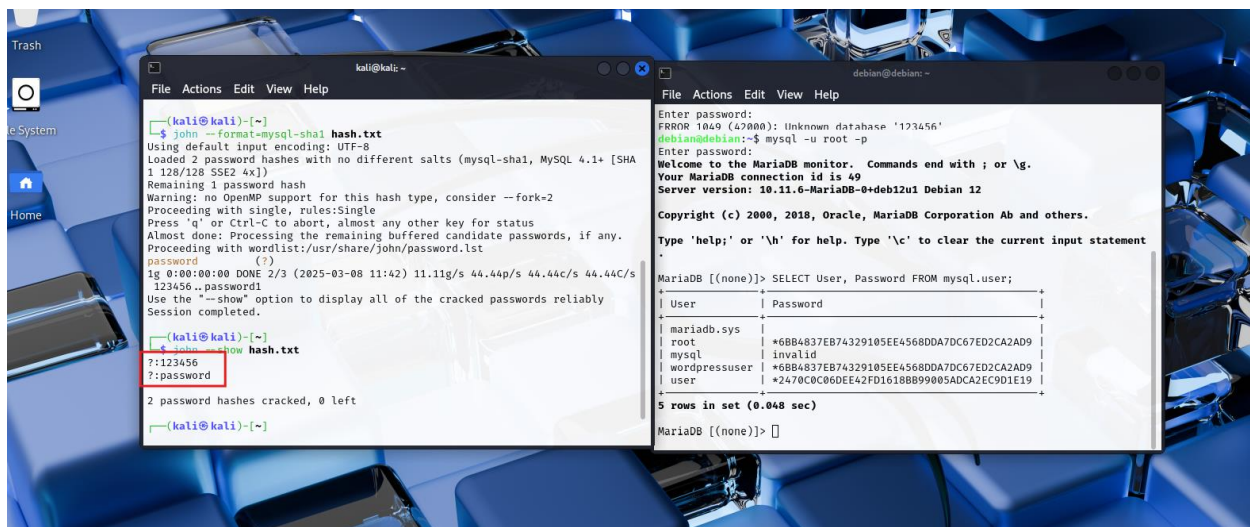






Se trató de realizar la explotación de las vulnerabilidades con los exploits que generó el análisis de vulnerabilidades, pero se determinó que eran muy antiguas y difíciles de encontrar sus exploits. Se descargó y aplicó John the Ripper para probar la fortaleza de las contraseñas de la base de datos desde la máquina Kali, donde se estaba realizando toda la investigación. El resultado arrojó contraseñas débiles y muy fáciles de adivinar.

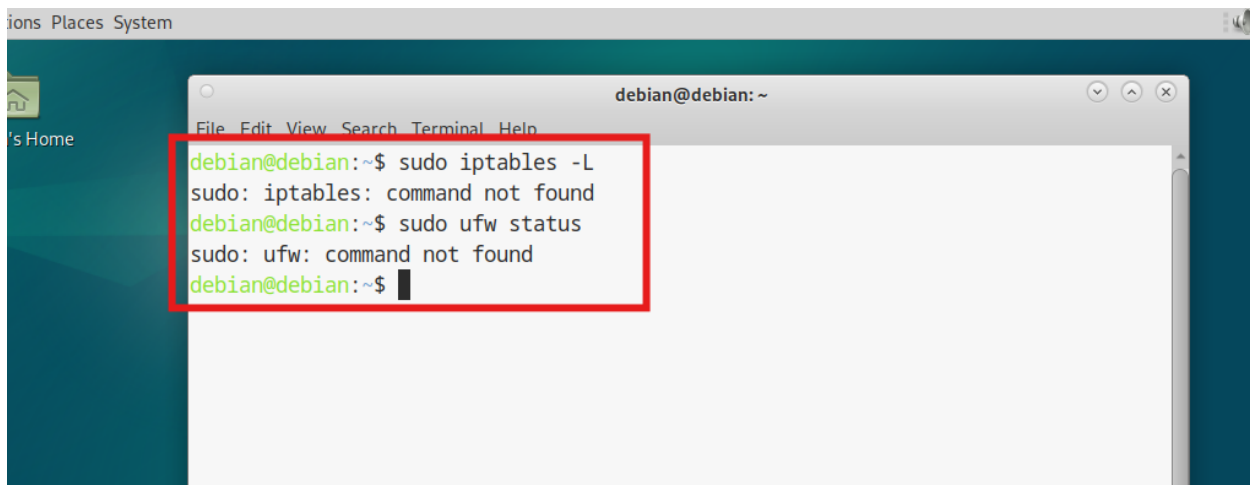




Mitigación

Habiendo realizado la investigación, encontrado vulnerabilidades y realizado ataques para verificar debilidades, se procedió a la mitigación.

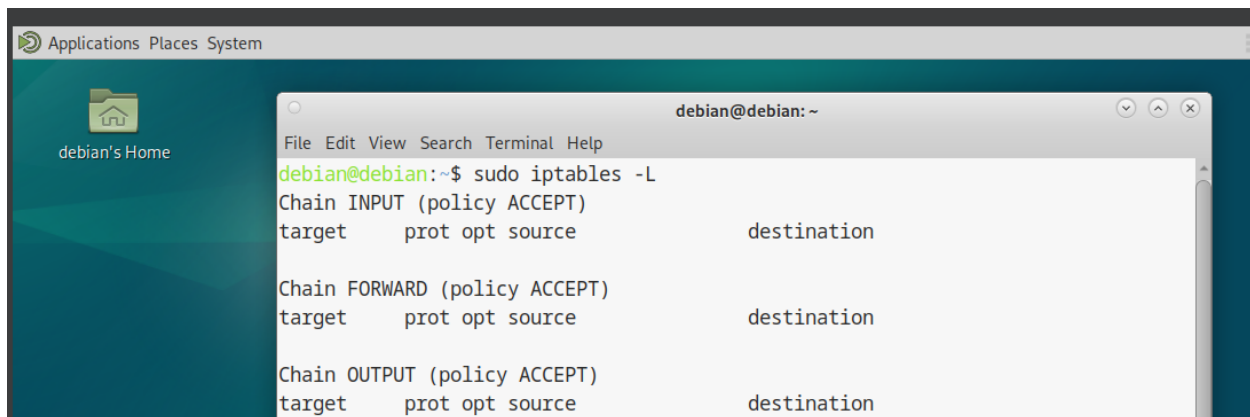
Se inició por verificar si se tenía un firewall. Se determinó que no estaba instalado, por lo cual se instaló y configuró con nftables. Específicamente, se bloqueó todo el tráfico entrante, permitiendo solo los servicios SSH, HTTP, HTTPS y el tráfico relacionado con conexiones ya establecidas. Se configuró un firewall restrictivo que bloquea todo el tráfico entrante no deseado, se permite el tráfico ICMP de tipo echo request para realizar pruebas de conectividad y el tráfico saliente no está restringido.



A terminal window titled 'debian@debian: ~' is shown. The window has a menu bar with 'File', 'Edit', 'View', 'Search', 'Terminal', and 'Help'. The terminal output shows the following commands and results:

```
debian@debian:~$ sudo iptables -L
sudo: iptables: command not found
debian@debian:~$ sudo ufw status
sudo: ufw: command not found
debian@debian:~$
```

The terminal window is overlaid on a desktop environment with a dark blue background and a sidebar on the left showing 'Home' and 'Places'.



A terminal window titled 'debian@debian: ~' is shown. The window has a menu bar with 'File', 'Edit', 'View', 'Search', 'Terminal', and 'Help'. The terminal output shows the following commands and results:

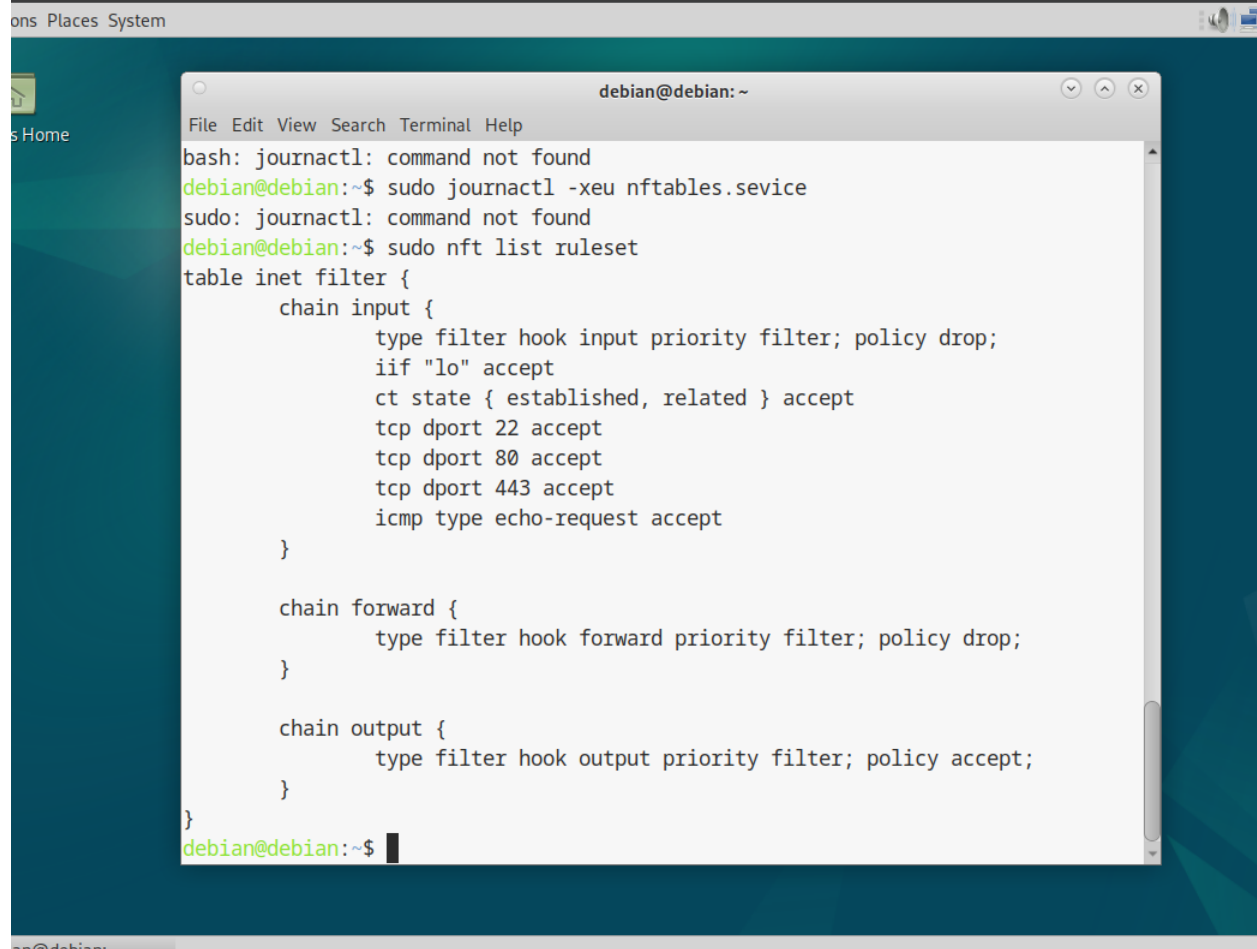
```
debian@debian:~$ sudo iptables -L
Chain INPUT (policy ACCEPT)
target    prot opt source                destination

Chain FORWARD (policy ACCEPT)
target    prot opt source                destination

Chain OUTPUT (policy ACCEPT)
target    prot opt source                destination
```

The terminal window is overlaid on a desktop environment with a dark blue background and a sidebar on the left showing 'Home' and 'Places'.

```
debian@debian:/$ systemctl status nftables
● nftables.service - nftables
   Loaded: loaded (/lib/systemd/system/nftables.service; enabled; preset: ena>
   Active: active (exited) since Tue 2025-03-04 20:55:47 -03; 3 days ago
     Docs: man:nft(8)
           http://wiki.nftables.org
   Process: 78516 ExecStart=/usr/sbin/nft -f /etc/nftables.conf (code=exited, >
   Process: 212136 ExecReload=/usr/sbin/nft -f /etc/nftables.conf (code=exited>
   Main PID: 78516 (code=exited, status=0/SUCCESS)
      CPU: 20ms
lines 1-9/9 (END)
```

A screenshot of a Linux desktop environment with a teal background. A terminal window titled 'debian@debian: ~' is open, displaying the output of several commands. The terminal shows that 'journalctl' is not found, and 'nft list ruleset' displays the current nftables configuration. The configuration includes three chains: 'input', 'forward', and 'output', each with specific filter rules. The 'input' chain has rules for 'lo', 'established, related', and ports 22, 80, 443, and echo-request. The 'forward' and 'output' chains are currently empty.

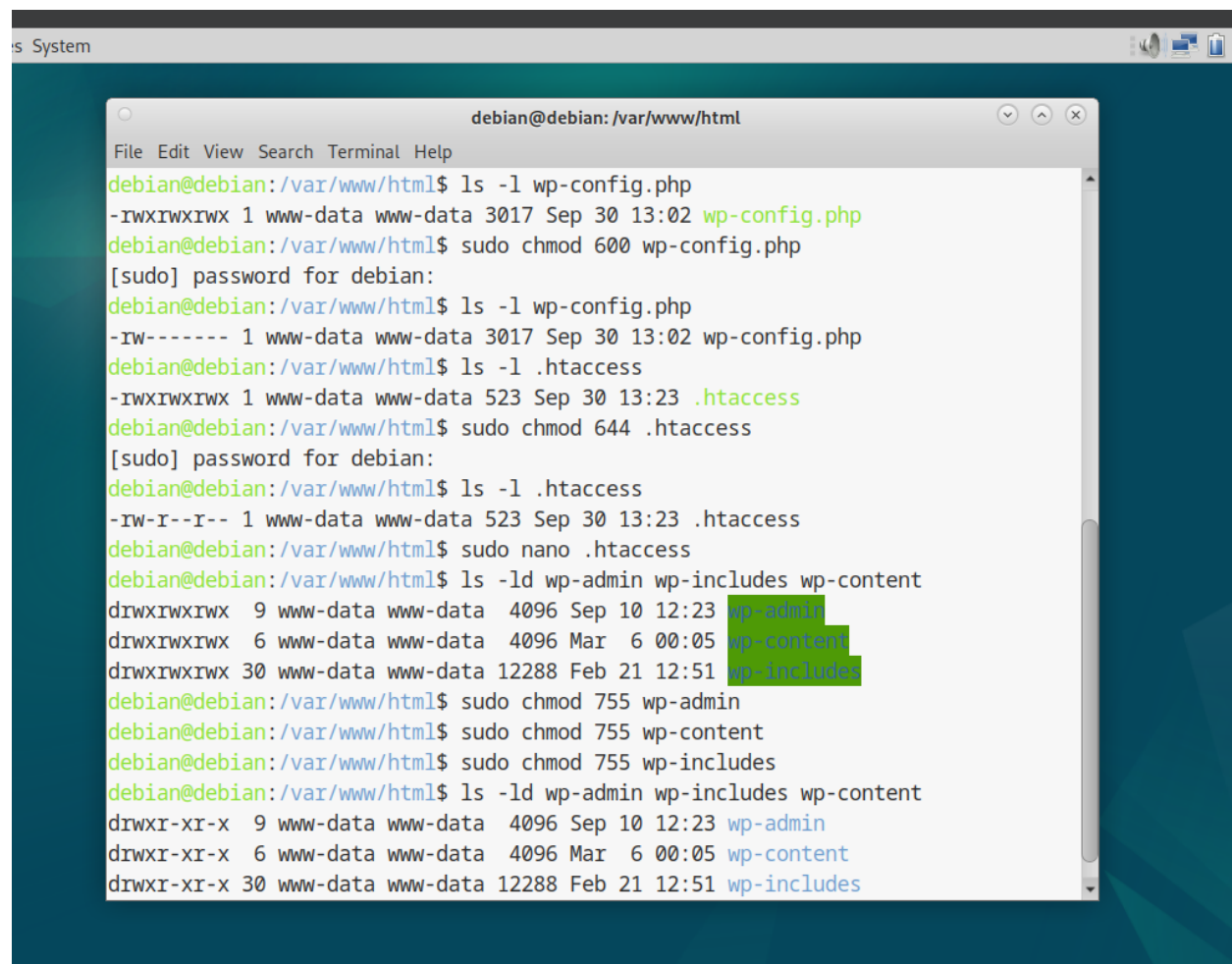
```
ons Places System
s Home

debian@debian: ~
File Edit View Search Terminal Help
bash: journalctl: command not found
debian@debian:~$ sudo journalctl -xeu nftables.service
sudo: journalctl: command not found
debian@debian:~$ sudo nft list ruleset
table inet filter {
    chain input {
        type filter hook input priority filter; policy drop;
        iif "lo" accept
        ct state { established, related } accept
        tcp dport 22 accept
        tcp dport 80 accept
        tcp dport 443 accept
        icmp type echo-request accept
    }

    chain forward {
        type filter hook forward priority filter; policy drop;
    }

    chain output {
        type filter hook output priority filter; policy accept;
    }
}
debian@debian:~$
```


Se configuró el directorio raíz de WordPress para que tuviera permisos de lectura y escritura solo para el propietario, y los demás usuarios solo tuvieran permisos de lectura. De igual manera, se configuró el archivo `.htaccess` para que el propietario tuviera permisos de lectura y escritura, y el grupo y otros usuarios tuvieran permisos de lectura, ya que este archivo controla el comportamiento del servidor. Además, se utilizó `sudo nano` para editar el archivo `.htaccess` y denegar el acceso a archivos `.php`, protegiendo así la información sensible. Los archivos `wp-admin`, `wp-includes` y `wp-content` también fueron modificados, cambiando las configuraciones de lectura, escritura y ejecución para el propietario, y estableciendo permisos de lectura y ejecución para los demás usuarios. Se configuraron los archivos `.php`, que tenían permisos excesivos, para que solo el propietario tuviera permisos de lectura y escritura, y los demás usuarios solo tuvieran permisos de lectura.



```
debian@debian: /var/www/html
File Edit View Search Terminal Help
debian@debian:/var/www/html$ ls -l wp-config.php
-rwxrwxrwx 1 www-data www-data 3017 Sep 30 13:02 wp-config.php
debian@debian:/var/www/html$ sudo chmod 600 wp-config.php
[sudo] password for debian:
debian@debian:/var/www/html$ ls -l wp-config.php
-rw----- 1 www-data www-data 3017 Sep 30 13:02 wp-config.php
debian@debian:/var/www/html$ ls -l .htaccess
-rwxrwxrwx 1 www-data www-data 523 Sep 30 13:23 .htaccess
debian@debian:/var/www/html$ sudo chmod 644 .htaccess
[sudo] password for debian:
debian@debian:/var/www/html$ ls -l .htaccess
-rw-r--r-- 1 www-data www-data 523 Sep 30 13:23 .htaccess
debian@debian:/var/www/html$ sudo nano .htaccess
debian@debian:/var/www/html$ ls -ld wp-admin wp-includes wp-content
drwxrwxrwx  9 www-data www-data 4096 Sep 10 12:23 wp-admin
drwxrwxrwx  6 www-data www-data 4096 Mar  6 00:05 wp-content
drwxrwxrwx 30 www-data www-data 12288 Feb 21 12:51 wp-includes
debian@debian:/var/www/html$ sudo chmod 755 wp-admin
debian@debian:/var/www/html$ sudo chmod 755 wp-content
debian@debian:/var/www/html$ sudo chmod 755 wp-includes
debian@debian:/var/www/html$ ls -ld wp-admin wp-includes wp-content
drwxr-xr-x  9 www-data www-data 4096 Sep 10 12:23 wp-admin
drwxr-xr-x  6 www-data www-data 4096 Mar  6 00:05 wp-content
drwxr-xr-x 30 www-data www-data 12288 Feb 21 12:51 wp-includes
```

```

debian@debian: /var/www/html$ ls -ld wp-admin wp-includes wp-content
drwxr-xr-x  9 www-data www-data 4096 Sep 10 12:23 wp-admin
drwxr-xr-x  6 www-data www-data 4096 Mar  6 00:05 wp-content
drwxr-xr-x 30 www-data www-data 12288 Feb 21 12:51 wp-includes
debian@debian: /var/www/html$ ls -l *.php
-rwxrwxrwx 1 www-data www-data  405 Feb  6 2020 index.php
-rwxrwxrwx 1 www-data www-data 7387 Feb 13 2024 wp-activate.php
-rwxrwxrwx 1 www-data www-data  351 Feb  6 2020 wp-blog-header.php
-rwxrwxrwx 1 www-data www-data 2323 Jun 14 2023 wp-comments-post.php
-rw----- 1 www-data www-data 3017 Sep 30 13:02 wp-config.php
-rwxrwxrwx 1 www-data www-data 3336 Feb 21 12:51 wp-config-sample.php
-rwxrwxrwx 1 www-data www-data 5617 Feb 21 12:51 wp-cron.php
-rwxrwxrwx 1 www-data www-data 2502 Nov 26 2022 wp-links-opml.php
-rwxrwxrwx 1 www-data www-data 3937 Mar 11 2024 wp-load.php
-rwxrwxrwx 1 www-data www-data 51367 Feb 21 12:51 wp-login.php
-rwxrwxrwx 1 www-data www-data  8543 Feb 21 12:51 wp-mail.php
-rwxrwxrwx 1 www-data www-data 29032 Feb 21 12:51 wp-settings.php
-rwxrwxrwx 1 www-data www-data 34385 Jun 19 2023 wp-signup.php
-rwxrwxrwx 1 www-data www-data  5102 Feb 21 12:51 wp-trackback.php
-rwxrwxrwx 1 www-data www-data  3246 Mar  2 2024 xmlrpc.php
debian@debian: /var/www/html$ sudo chmod 644 *.php

```

```

debian@debian: /var/www/html$ ls -l *.php
-rw-r--r-- 1 www-data www-data  405 Feb  6 2020 index.php
-rw-r--r-- 1 www-data www-data 7387 Feb 13 2024 wp-activate.php
-rw-r--r-- 1 www-data www-data  351 Feb  6 2020 wp-blog-header.php
-rw-r--r-- 1 www-data www-data 2323 Jun 14 2023 wp-comments-post.php
-rw----- 1 www-data www-data 3017 Sep 30 13:02 wp-config.php
-rw-r--r-- 1 www-data www-data 3336 Feb 21 12:51 wp-config-sample.php
-rw-r--r-- 1 www-data www-data 5617 Feb 21 12:51 wp-cron.php
-rw-r--r-- 1 www-data www-data 2502 Nov 26 2022 wp-links-opml.php
-rw-r--r-- 1 www-data www-data 3937 Mar 11 2024 wp-load.php
-rw-r--r-- 1 www-data www-data 51367 Feb 21 12:51 wp-login.php
-rw-r--r-- 1 www-data www-data  8543 Feb 21 12:51 wp-mail.php
-rw-r--r-- 1 www-data www-data 29032 Feb 21 12:51 wp-settings.php
-rw-r--r-- 1 www-data www-data 34385 Jun 19 2023 wp-signup.php
-rw-r--r-- 1 www-data www-data  5102 Feb 21 12:51 wp-trackback.php
-rw-r--r-- 1 www-data www-data  3246 Mar  2 2024 xmlrpc.php
debian@debian: /var/www/html$ sudo nano htaccess

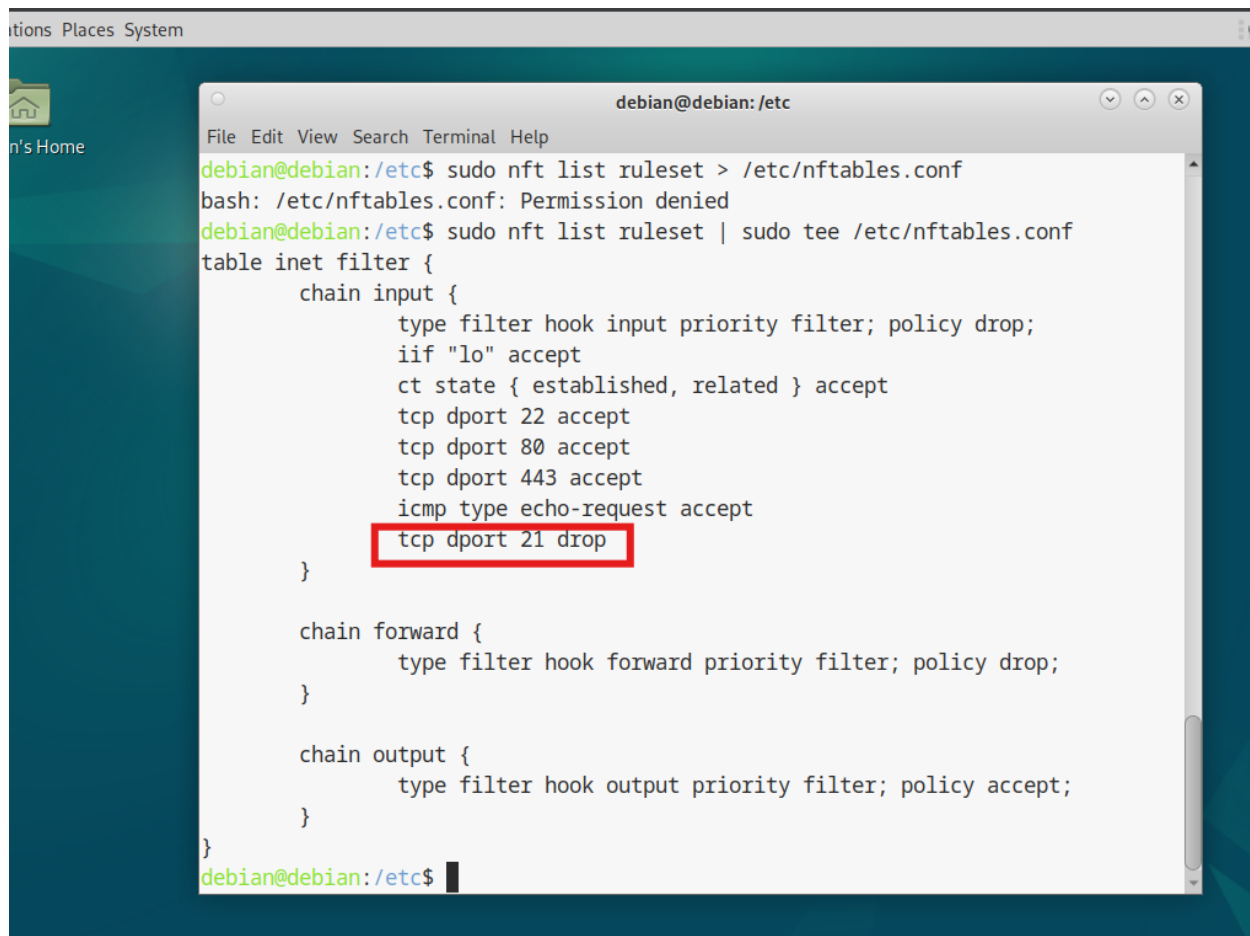
```

La siguiente debilidad a corregir fue el acceso anónimo por FTP, el cual se deshabilitó. Se configuró el sistema para que no se permitieran conexiones por FTP, ya que el servicio SFTP funciona a través del puerto 22.

```
debian@debian: /etc
File Edit View Search Terminal Help
GNU nano 7.2 vsftpd.conf *
# capabilities.
#
#
# Run standalone? vsftpd can run either from an inetd or as a standalone
# daemon started from an initscript.
listen=NO
#
# This directive enables listening on IPv6 sockets. By default, listening
# on the IPv6 "any" address (::) will accept connections from both IPv6
# and IPv4 clients. It is not necessary to listen on *both* IPv4 and IPv6
# sockets. If you want that (perhaps because you want to listen on specific
# addresses) then you must run two copies of vsftpd with two configuration
# files.
listen_ipv6=YES
#
# Allow anonymous FTP? (Disabled by default).
#anonymous_enable=YES
#
# Uncomment this to allow local users to log in.
local_enable=YES

^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute   ^C Location
^X Exit      ^R Read File ^\ Replace   ^U Paste     ^J Justify   ^_ Go To Line
```

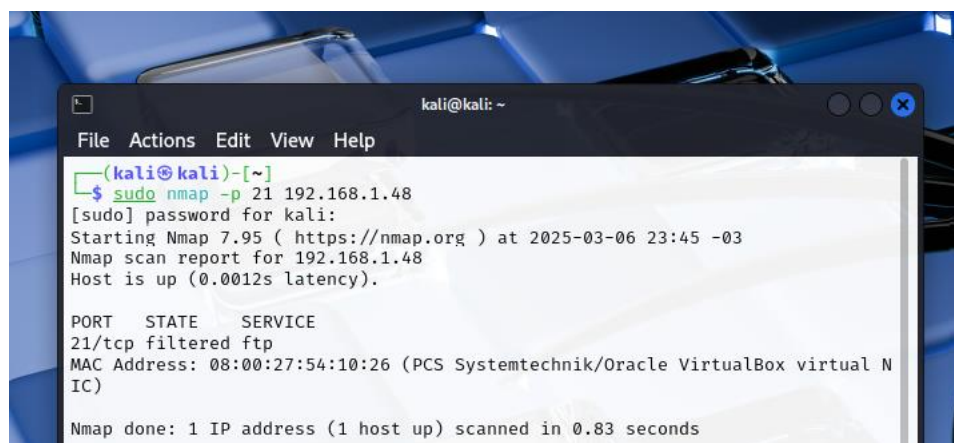
```
debian@debian:/etc$ sudo systemctl restart vsftpd
debian@debian:/etc$
```



```
debian@debian:/etc$ sudo nft list ruleset > /etc/nftables.conf
bash: /etc/nftables.conf: Permission denied
debian@debian:/etc$ sudo nft list ruleset | sudo tee /etc/nftables.conf
table inet filter {
    chain input {
        type filter hook input priority filter; policy drop;
        iif "lo" accept
        ct state { established, related } accept
        tcp dport 22 accept
        tcp dport 80 accept
        tcp dport 443 accept
        icmp type echo-request accept
        tcp dport 21 drop
    }

    chain forward {
        type filter hook forward priority filter; policy drop;
    }

    chain output {
        type filter hook output priority filter; policy accept;
    }
}
debian@debian:/etc$
```



```
kali@kali: ~
File Actions Edit View Help
(kali@kali)~[~]
$ sudo nmap -p 21 192.168.1.48
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-06 23:45 -03
Nmap scan report for 192.168.1.48
Host is up (0.0012s latency).

PORT      STATE      SERVICE
21/tcp    filtered  ftp
MAC Address: 08:00:27:54:10:26 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.83 seconds
```

Para la vulnerabilidad de listado web, se configuró apache2.conf para deshabilitar esta funcionalidad.
Nota: Las siguientes dos imágenes demuestran la configuración antes y después de la modificación.

```
System

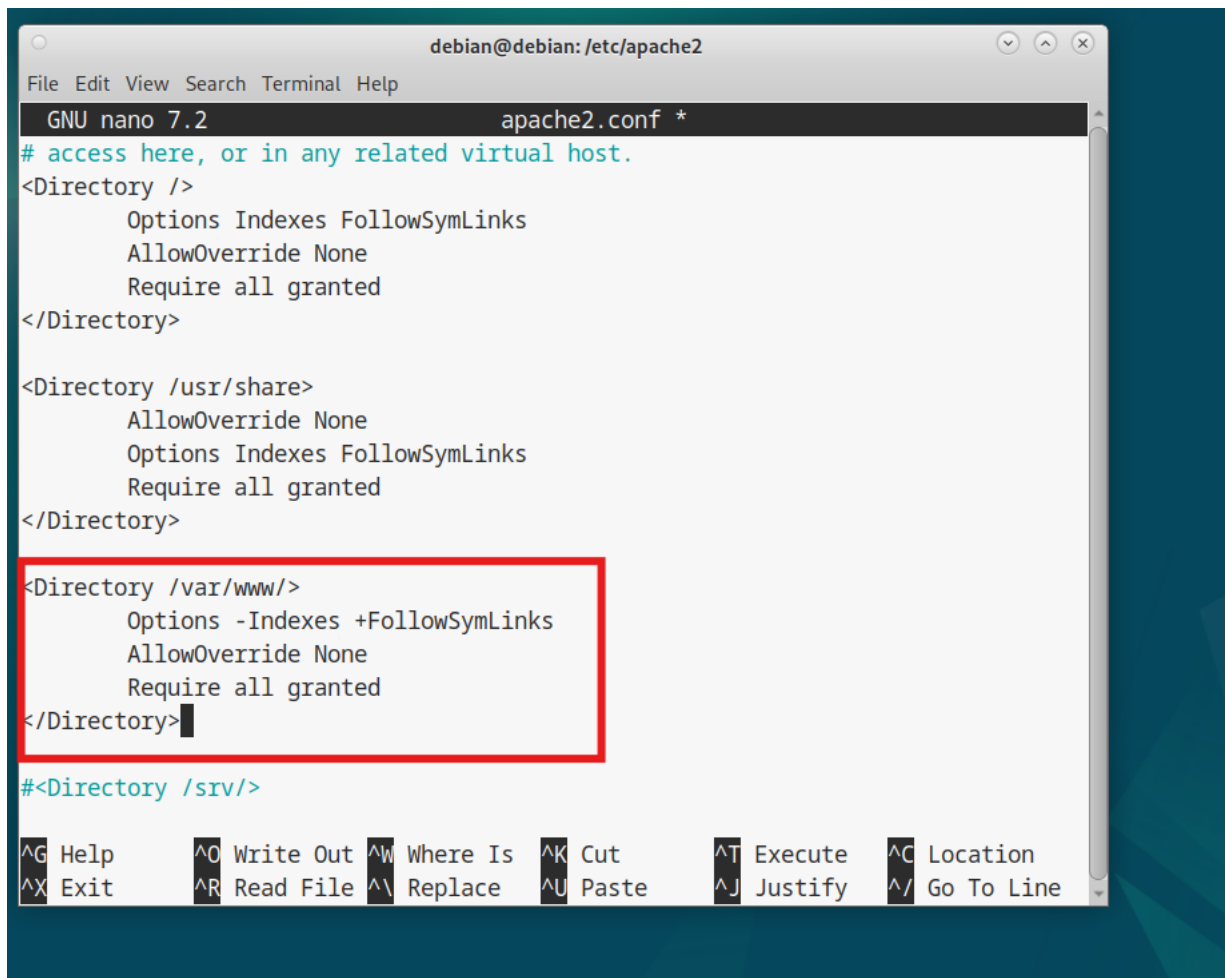
debian@debian: /etc/apache2
File Edit View Search Terminal Help
GNU nano 7.2 apache2.conf *
# access here, or in any related virtual host.
<Directory />
    Options Indexes FollowSymLinks
    AllowOverride None
    Require all granted
</Directory>

<Directory /usr/share>
    AllowOverride None
    Options Indexes FollowSymLinks
    Require all granted
</Directory>

<Directory /var/www/>
    Options Indexes FollowSymLinks
    AllowOverride None
    Require all granted
</Directory>

#<Directory /srv/>

^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute  ^C Location
^X Exit      ^R Read File ^\ Replace   ^U Paste     ^J Justify  ^_ Go To Line
```

```
debian@debian: /etc/apache2
File Edit View Search Terminal Help
GNU nano 7.2 apache2.conf *
# access here, or in any related virtual host.
<Directory />
    Options Indexes FollowSymLinks
    AllowOverride None
    Require all granted
</Directory>

<Directory /usr/share>
    AllowOverride None
    Options Indexes FollowSymLinks
    Require all granted
</Directory>

<Directory /var/www/>
    Options -Indexes +FollowSymLinks
    AllowOverride None
    Require all granted
</Directory>

#<Directory /srv/>

^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute   ^C Location
^X Exit      ^R Read File ^\ Replace   ^U Paste     ^J Justify   ^_ Go To Line
```

La siguiente mitigación fue configurar correctamente los usuarios de la base de datos. Se realizó el cambio de contraseñas por unas más robustas y, por último, se modificaron los privilegios excesivos del usuario wordpressuser a los necesarios.



```
MariaDB [mysql]> DROP USER 'user'@'localhost';
Query OK, 0 rows affected (0.039 sec)

MariaDB [mysql]> FLUSH PRIVILEGES
-> FLUSH PRIVILEGES;
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that
corresponds to your MariaDB server version for the right syntax to use near 'FLU
SH PRIVILEGES' at line 2
MariaDB [mysql]> FLUSH PRIVILEGES;
Query OK, 0 rows affected (0.024 sec)

MariaDB [mysql]> exit
Bye
```

```
MariaDB [(none)]> ALTER USER 'root'@'localhost' IDENTIFIED BY 'Nueva1CON2seg..';
```

```
Query OK, 0 rows affected (0.020 sec)
```

```
MariaDB [(none)]> ALTER USER 'wordpressuser'@'localhost' IDENTIFIED BY '.conWORD7seg.';
```

```
Query OK, 0 rows affected (0.019 sec)
```

```
MariaDB [(none)]> FLUSH PRIVILEGES
```

```
-> EXIT
```

```
-> FLUSH PRIVILEGES;
```

```
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near 'EXIT
```

```
FLUSH PRIVILEGES' at line 2
```

```
MariaDB [(none)]> FLUSH PRIVILEGES;
```

```
Query OK, 0 rows affected (0.018 sec)
```

```
MariaDB [(none)]> exit
```

```
MariaDB [(none)]> USE wordpress
```

```
Reading table information for completion of table and column names
```

```
You can turn off this feature to get a quicker startup with -A
```

```
Database changed
```

```
MariaDB [wordpress]> GRANT SELECT, INSERT, UPDATE, DELETE, CREATE, DROP, INDEX, ALTER, CREATE TEMPORARY TABLES, LOCK TABLES ON wordpress* TO 'wordpressuser'@'localhost';
```

```
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near '* T O 'wordpressuser'@'localhost'' at line 1
```

```
MariaDB [wordpress]> GRANT SELECT, INSERT, UPDATE, DELETE, CREATE, DROP, INDEX, ALTER, CREATE TEMPORARY TABLES, LOCK TABLES ON wordpress.* TO 'wordpressuser'@'localhost';
```

```
Query OK, 0 rows affected (0.022 sec)
```

```
MariaDB [wordpress]> FLUSH PRIVILEGES;
```

```
Query OK, 0 rows affected (0.018 sec)
```

```
MariaDB [wordpress]> █
```

```
es System

debian@debian: /var/www/html
File Edit View Search Terminal Help

| Grants for wordpressuser@localhost
+-----+
| GRANT USAGE ON *.* TO `wordpressuser`@`localhost` IDENTIFIED BY PASSWORD '*DD78403750D967CE495A11CAC7933A9E927AAE11' |
| GRANT ALL PRIVILEGES ON `wordpress`.* TO `wordpressuser`@`localhost`
+-----+
2 rows in set (0.016 sec)

MariaDB [wordpress]> SHOW GRANTS FOR 'root'@'localhost';
+-----+
| Grants for root@localhost
+-----+
| GRANT ALL PRIVILEGES ON *.* TO `root`@`localhost` IDENTIFIED BY PASSWORD '*529A75B4D6DBEE7BB237B3C9B7F66CB30361FD36' WITH GRANT OPTION |
| GRANT PROXY ON ''@%' TO 'root'@'localhost' WITH GRANT OPTION
+-----+
```

Luego, se procedió a realizar la configuración adecuada de SSH. La principal acción fue deshabilitar el acceso a root a través de SSH. Posteriormente, se actualizó OpenSSH a la última versión.

The image shows a terminal window titled 'debian@debian: /' with a menu bar (File, Edit, View, Search, Terminal, Help). The editor is GNU nano 7.2, editing /etc/ssh/sshd_config. The file content is as follows:

```
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
#PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
```

A red rectangle highlights the line `#PermitRootLogin no`. At the bottom of the terminal, a keyboard shortcuts menu is visible:

^G Help	^O Write Out	^W Where Is	^K Cut	^T Execute	^C Location
^X Exit	^R Read File	^\ Replace	^U Paste	^J Justify	^_ Go To Line

```
m
debian@debian: /
File Edit View Search Terminal Help
Setting up ure (4:7.4.7-1+deb12u7) ...
Setting up libreoffice-common (4:7.4.7-1+deb12u7) ...
Setting up libreoffice-core (4:7.4.7-1+deb12u7) ...
Setting up libreoffice-math (4:7.4.7-1+deb12u7) ...
Setting up libreoffice-gtk3 (4:7.4.7-1+deb12u7) ...
Setting up libreoffice-draw (4:7.4.7-1+deb12u7) ...
Setting up libreoffice-help-common (4:7.4.7-1+deb12u7) ...
Setting up libreoffice-impress (4:7.4.7-1+deb12u7) ...
Setting up libreoffice-base-core (4:7.4.7-1+deb12u7) ...
Setting up libreoffice-help-en-us (4:7.4.7-1+deb12u7) ...
Setting up python3-uno (4:7.4.7-1+deb12u7) ...
Setting up libreoffice-calc (4:7.4.7-1+deb12u7) ...
Setting up libreoffice-writer (4:7.4.7-1+deb12u7) ...
Processing triggers for mate-menus (1.26.0-3) ...
Processing triggers for libc-bin (2.36-9+deb12u9) ...
Processing triggers for man-db (2.11.2-2) ...
Processing triggers for shared-mime-info (2.2-1) ...
Processing triggers for mailcap (3.70+nmu1) ...
Processing triggers for fontconfig (2.14.1-4) ...
Processing triggers for desktop-file-utils (0.26-1) ...
Processing triggers for hicolor-icon-theme (0.17-2) ...
debian@debian:/$ ssh -V
OpenSSH_9.2p1 Debian-2+deb12u5, OpenSSL 3.0.15 3 Sep 2024
debian@debian:/$
```


Propuesta de prevención

La prevención debe ser primordial, y al tener un plan de prevención, es más fácil ejecutar las acciones necesarias. Por ejemplo, en algo tan sencillo como las actualizaciones, estas se tienen que gestionar de manera recurrente para que las vulnerabilidades sean parcheadas.

Se recomienda implementar actualizaciones automáticas (para parchear vulnerabilidades y actualizar), y se debe monitorear estas actualizaciones automáticas con frecuencia para verificar que todo esté normal.

Siempre se debe aplicar configuraciones de usuario aplicando el principio de menor privilegio.

Se debe asegurar de tener contraseñas robustas para todo el sistema (autenticación multifactor), revisarlas con frecuencia y cambiarlas.

Todo en ciberseguridad es un conjunto de configuraciones y uso de herramientas, por lo cual es importante verificar frecuentemente todo: contraseñas, usuarios, permisos, actualizaciones, etc.

Se recomienda implementar un sistema de gestión de logs (donde se registra todo lo que sucede) en el sistema.

Vale acotar que siempre hay que mantenerse actualizado sobre cualquier herramienta que funcione para la seguridad, ya que el panorama de amenazas cambia a diario.